

第十九届全国大学生信息安全竞赛（作品赛）
暨第三届”长城杯”网数智安全大赛（作品赛）
作品报告

☐ 命题赛道

☒ 自由赛道

作品名称： FoodShield——外卖订单隐私认证与可信审计系统

电子邮箱： 3863102544@qq.com

提交日期： 2026 年 7 月 3 日

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用 A4 纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5 倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。

目 录

摘要	5
第一章 作品概述	7
1.1 背景分析	7
1.1.1 外卖平台即时通信功能的普及与安全风险	7
1.1.2 外卖订单通信中的四类安全问题	8
1.1.3 国密算法推广与相关政策法规背景	8
1.2 相关工作与现有方案不足	9
1.3 作品目标	10
1.4 我们的工作	11
1.5 应用前景	13
第二章 预备知识	14
2.1 HMAC 消息认证码	14
2.2 SM3 密码杂凑算法	16
2.3 SM4 对称加密算法	17
2.4 PID 匿名身份机制	19
2.5 WebSocket 实时通信机制	20
2.6 Merkle Tree 完整性验证	22
2.7 条件溯源与可控匿名模型	24
第三章 系统设计	27
3.1 系统总体方案	27
3.2 系统参与方与信任边界	28
3.3 威胁模型	30
3.4 安全目标	32
3.5 系统总体架构	34
3.6 数据库设计	36
3.7 用户注册与防机器注册机制	41
3.8 PID 匿名身份生成机制	43
3.9 订单 Token 认证机制	44
3.10 用户端与骑手端匿名通信机制	47
3.11 消息加密存储与哈希摘要机制	49

3.12	Merkle 日志完整性验证机制	51
3.13	条件溯源与管理员审计机制	53
3.14	三端摘要一致性增强机制	55
3.15	方案安全性分析	57
第四章	作品实现	60
4.1	系统开发环境	60
4.2	后端服务实现	60
4.3	用户端功能实现	60
4.4	骑手端功能实现	60
4.5	管理员端功能实现	60
4.6	注册、下单与订单认证流程实现	60
4.7	WebSocket 通信流程实现	60
4.8	Merkle 快照与完整性验证实现	60
4.9	条件溯源流程实现	60
4.10	系统运行界面	60
第五章	作品测试与分析	61
5.1	测试环境	61
5.2	功能测试	61
5.3	安全性测试	61
5.4	日志篡改检测测试	61
5.5	越权访问测试	61
5.6	性能测试	61
5.7	对比分析	61
第六章	功能展示与创新性说明	62
6.1	场景创新	62
6.2	机制创新	62
6.3	安全模型创新	62
6.4	系统闭环创新	62
6.5	应用价值	62
第七章	总结	63
7.1	作品总结	63
7.2	未来展望	63

参考文献 64

摘要

随着外卖平台即时通信功能的广泛使用，用户与骑手之间的订单沟通在提升配送效率的同时，也带来了**身份信息暴露、订单通信越权、聊天记录篡改以及纠纷追责困难**等安全问题。在传统外卖订单通信模式下，用户身份、订单身份与通信身份往往绑定较紧，骑手端或平台管理端可能接触到超出配送所需范围的用户信息；同时，普通订单聊天系统主要关注业务连通性，缺少针对订单参与方合法性、通信日志可信性和异常责任追踪的系统化安全设计。当发生恶意骚扰、虚假投诉、订单纠纷或通信记录被篡改等情况时，平台既需要保护用户隐私，又需要具备必要的审计和治理能力。因此，如何在外卖订单通信场景中同时实现身份匿名、订单认证、日志可信和条件溯源，成为一个具有实际应用价值的信息安全问题。

针对上述问题，我们设计并实现了一种面向外卖平台的隐私认证与可信审计系统——FoodShield。系统以“**日常匿名、异常可溯源**”为设计原则，通过 PID 匿名身份机制隐藏用户真实身份，通过基于 HMAC-SM3 的订单 Token 机制验证通信参与方的订单合法性，通过 WebSocket 实现用户端与骑手端的订单级实时通信，并结合 SM4 加密存储、SM3 消息摘要和 Merkle Tree 日志完整性验证机制，实现订单通信数据的安全保护与可信审计。其中，系统采用 **128 bit** 对称密钥进行消息加密，使用 SM3 生成 **256 bit** 消息摘要，并将 **256 bit** 摘要值作为 Merkle Tree 叶子节点和根节点计算基础，从而为消息存储和日志审计提供密码学安全支撑。在异常投诉或平台审计场景下，系统支持用户端和骑手端基于订单号发起溯源申请，管理员经过权限校验后执行条件溯源，并将关键操作写入审计日志，从而在隐私保护与平台治理之间形成平衡。

本作品的技术优势和创新性如下：

1. 基于外卖订单场景的可控匿名通信模型

本作品不是单纯的匿名聊天系统，而是面向外卖订单通信场景设计了可控匿名模型。系统在日常通信过程中不直接暴露用户真实身份，骑手端仅能看到订单相关的必要信息，无法获得用户真实标识或 PID；当发生投诉、纠纷或异常行为时，平台可在权限控制和审计记录约束下基于订单号进行条件溯源。该机制兼顾了用户隐私保护与平台责任追踪需求，避免了“完全匿名不可治理”和“直接实名过度暴露”两类问题。

2. 基于 HMAC-SM3 的匿名订单认证机制

本作品设计了订单 Token 认证机制，将订单编号、匿名身份标识、时间戳和随

机数等字段作为待认证消息，并使用订单认证密钥计算 HMAC-SM3 值。由于 SM3 输出长度为 **256 bit**，攻击者在不知道订单认证密钥的情况下难以构造合法 Token；同时，Token 中引入时间戳和 **128 bit** 随机数，能够降低认证凭证被重放或预测的风险。用户进入订单通信通道时需要提交订单号和 Token，服务器重新计算并验证 Token 的合法性、订单归属关系和时效性。该机制使用户能够在不暴露真实身份的情况下证明自己是合法订单参与方，降低了非法用户伪造订单身份进入通信通道的风险。

3. 基于 Merkle Tree 的通信日志可信审计机制

本作品将订单通信日志的消息摘要作为 Merkle Tree 的叶子节点，逐层计算生成 Merkle Root，并通过快照机制保存订单通信记录在特定时刻的完整性状态。系统中每条消息日志均绑定订单号、发送方角色、时间戳、消息序号和密文摘要等字段，最终生成 **256 bit** 的 Merkle Root。若攻击者修改、删除、插入或重排历史消息，重新计算得到的 Merkle Root 将与历史快照不一致，从而能够检测日志篡改行为。在理想哈希假设下，攻击者伪造指定 SM3 摘要的复杂度约为 2^{256} ，寻找任意碰撞的复杂度约为 2^{128} ，因此该机制能够为通信日志完整性提供较高强度的密码学保障。该机制提升了平台在订单纠纷处理中的证据可信度，使通信记录不仅能够被保存，而且能够被验证。

4. 隐私保护与管理审计相结合的系统闭环

本作品实现了用户端、骑手端和管理员端的完整业务闭环，涵盖用户注册、订单创建、订单认证、匿名通信、消息加密存储、日志快照、完整性验证、投诉申请和条件溯源等功能。管理员端默认不展示通信明文内容，而是以订单摘要、消息哈希、Merkle Root 和审计日志作为主要查看对象，降低了管理权限带来的二次隐私泄露风险。系统测试表明，FoodShield 能够完成订单通信流程，并在非法 Token 接入、日志篡改和管理员越权访问等场景下进行有效检测或限制。

关键词：外卖平台；可控匿名；订单认证；PID；HMAC-SM3；Merkle Tree；条件溯源；可信审计

作品概述

1.1 背景分析

1.1.1 外卖平台即时通信功能的普及与安全风险

近年来，外卖平台已成为我国数字经济中规模最大、渗透率最高的生活服务场景之一。根据中国互联网络信息中心 (CNNIC) 发布的统计报告，截至 2024 年 12 月，我国网上外卖用户规模已达 5.92 亿人，占网民整体的 53.4%；至 2025 年 12 月，该规模进一步增长至 6.30 亿人，占网民整体的 56.0%¹。中国饭店协会数据显示，2023 年我国餐饮外卖市场规模约 1.2 万亿元，占餐饮收入的比重升至 22.6%²。外卖服务已从单纯的餐饮配送延伸至即时零售、药品配送、生鲜采购等多元场景，成为支撑城市生活运转的重要基础设施。

在庞大的用户基数和业务规模驱动下，外卖平台普遍引入了用户与骑手之间的即时通信 (Instant Messaging) 功能。该功能允许用户在订单创建后通过平台内置的聊天界面与配送骑手进行实时沟通，用于确认配送地址、沟通特殊需求、反馈配送问题等。然而，即时通信功能在提升配送效率的同时，也引入了新的安全隐患。与传统的电话沟通不同，订单即时通信产生的是可持久化存储的文本消息记录，这些记录中可能包含用户的家庭住址、生活习惯、消费偏好等敏感信息；同时，通信参与方的身份信息、订单信息与通信内容在系统中高度关联，一旦安全防护不足，将导致用户隐私的大面积暴露。

2025 年 4 月，四川成都的王女士在外卖平台购买消毒液和计生用品后，配送骑手竟向其发送包含商品明细的骚扰短信³。该事件表明，即便平台声称采用了虚拟号码加密技术，配送员仍可通过技术漏洞获取用户的真实手机号码及订单商品明细，并据此实施骚扰。类似事件并非个案：贵州省龙里县人民法院审结的一起案件中，某快递公司装车员在“每条信息 0.8 元”的利诱下连续偷拍快递面单，将数千条包含姓名、电话、住址及购买物品的隐私信息上传至网盘交易，最终 4 名涉案人员因侵犯公民个人信息罪获刑⁴。上述案例揭示了配送行业长期存在的隐私泄露隐患——在缺乏系统性安全设计的订单通信体系中，用户隐私处于事实上的“裸奔”状态。

¹数据来源：中国互联网络信息中心 (CNNIC)《中国互联网络发展状况统计报告》，中商产业研究院整理。

²数据来源：中国饭店协会，转引自中国发展网 2025 年 2 月报道。

³参见《法治日报》2025 年 5 月 8 日第 4 版“法治经纬”栏目报道，新华社同步跟进报道。

⁴参见贵州省龙里县人民法院相关案件审理报道，载于《法治日报》2025 年 5 月 8 日。

1.1.2 外卖订单通信中的四类安全问题

通过对现有外卖平台订单通信流程的分析，并结合上述真实安全事件，我们归纳出外卖订单通信场景中存在的四类核心安全问题：

(1) 身份信息暴露。在传统外卖订单通信模式下，用户身份、订单身份与通信身份往往紧密绑定。骑手端在接单后可以直接获取用户的真实姓名、手机号码、收货地址等敏感信息，部分平台虽采用了虚拟号码技术，但据《法治日报》调查，实际运营中仍存在虚拟号短信通道未加密、多次通话后自动关联真实号码、配送端页面未完全屏蔽敏感字段等技术缺陷⁵。这些缺陷使得骑手能够在配送过程中获取超出业务必要范围的用户个人信息，进而可能引发骚扰、恐吓等二次侵害。

(2) 订单通信越权。现有外卖平台的即时通信功能主要关注业务连通性，缺乏对订单参与方合法性的系统化认证机制。在实际场景中，攻击者可能通过伪造订单身份、复用历史订单凭证或利用系统权限漏洞进入非自身订单的通信通道，从而窃取其他用户的通信内容或进行恶意骚扰。由于缺少基于密码学的订单认证机制，平台难以在不暴露用户真实身份的前提下验证通信参与方是否为合法的订单相关方。

(3) 聊天记录篡改。外卖订单通信产生的消息记录在发生配送纠纷、恶意投诉或法律诉讼时具有重要的证据价值。然而，现有平台的通信日志存储于平台中心化数据库中，既缺乏密码学完整性保护机制，也缺乏独立的第三方验证手段。当平台自身或具有数据库访问权限的内部人员篡改、删除或插入消息记录时，用户和监管机构难以发现和证明记录已被修改，从而导致通信记录的证据可信度不足。

(4) 纠纷追责困难。在完全匿名或弱匿名的通信环境中，用户和骑手之间的恶意行为（如骚扰、威胁、虚假投诉等）难以溯源到真实责任主体。如果系统默认暴露真实身份，则又会削弱隐私保护效果，形成“完全匿名不可治理”与“直接实名过度暴露”的两难困境。如何在保护日常通信隐私的同时保留异常情况下的条件溯源能力，是外卖订单通信安全需要解决的关键问题。

1.1.3 国密算法推广与相关法律法规背景

在外卖订单通信安全问题的技术层面，密码算法的选择至关重要。长期以来，我国信息系统中广泛使用 RSA、AES、SHA-256 等国际密码算法，但这些算法存在被植入后门或存在未公开弱点等潜在风险。为保障国家信息安全，我国大力推进商用密码算法的自主研发和推广应用。

2019 年 10 月 26 日，第十三届全国人民代表大会常务委员会第十四次会议通过

⁵ 参见《法治日报》2025 年 5 月 8 日第 4 版调查报道。

《中华人民共和国密码法》，自 2020 年 1 月 1 日起施行⁶。该法明确将密码分为核心密码、普通密码和商用密码，规定商用密码用于保护不属于国家秘密的信息，鼓励商用密码技术的研究开发、学术交流、成果转化和推广应用。在密码法的框架下，国家密码管理局陆续发布了 SM 系列商用密码算法标准，其中 SM3 密码杂凑算法（GB/T 32905-2016）输出 256 bit 消息摘要，SM4 分组密码算法（GB/T 32907-2016）采用 128 bit 分组长度和 128 bit 密钥长度，SM2 椭圆曲线公钥密码算法（GB/T 32918）提供了数字签名、密钥交换和公钥加密等功能⁷。这些国密算法已在金融、电力、政务、交通等领域得到广泛应用，为我国信息系统的安全自主可控提供了技术基础。

在个人信息保护层面，2021 年 8 月 20 日通过的《中华人民共和国个人信息保护法》（自 2021 年 11 月 1 日起施行）确立了处理个人信息应遵循的“合法、正当、必要和诚信原则”，并明确提出了“最小必要原则”——处理个人信息应当具有明确、合理的目的，并应当与处理目的直接相关，采取对个人权益影响最小的方式⁸。对于外卖配送场景而言，配送员仅需知晓收件人地址和虚拟号码，商品明细、真实电话号码等均属非必要信息，不应向配送环节披露⁹。此外，《中华人民共和国数据安全法》（自 2021 年 9 月 1 日起施行）要求数据处理者建立健全全流程数据安全管理制度，采取相应的技术措施保障数据安全¹⁰。国务院颁布的《“十四五”数字经济发展规划》亦提出要加强数据加密技术发展，提升数字经济安全体系的保障能力¹¹。

上述法律法规和政策文件为外卖订单通信安全系统的设计提供了明确的合规指引：系统应当在“最小必要原则”的指导下，采用国密算法构建身份匿名、订单认证、消息保护和日志审计机制，在保护用户隐私的同时满足平台治理和纠纷追责的监管要求。

1.2 相关工作与现有方案不足

针对外卖订单通信中的安全问题，学术界和产业界已开展了一定的研究和实践，但现有方案在系统性、安全性和适用性方面仍存在不足。

现有外卖平台的隐私保护措施。以美团、饿了么为代表的外卖平台已推出虚拟号码、隐私面单等隐私保护功能。例如，美团规则中心规定商家和骑手需通过平台生

⁶ 《中华人民共和国密码法》，主席令第三十五号，2019 年 10 月 26 日公布，自 2020 年 1 月 1 日起施行。

⁷ GB/T 32905-2016《信息安全技术 SM3 密码杂凑算法》；GB/T 32907-2016《信息安全技术 SM4 分组密码算法》；GB/T 32918《信息安全技术 SM2 椭圆曲线公钥密码算法》。

⁸ 《中华人民共和国个人信息保护法》第五条、第六条。

⁹ 参见《法治日报》2025 年 5 月 8 日第 4 版，中国传媒大学程科副教授及北京嘉潍律师事务所赵占领律师的专家意见。

¹⁰ 《中华人民共和国数据安全法》第二十七条。

¹¹ 《“十四五”数字经济发展规划》，国务院 2021 年 12 月印发。

成的虚拟号码联系用户，虚拟号码过期后即无法再行联系¹²。然而，这些措施主要针对电话通信环节的号码脱敏，并未覆盖订单即时通信的全流程。如前文所述，虚拟号码技术在实际部署中存在短信通道未加密、多次通话后关联真实号码等漏洞；同时，现有平台缺乏对聊天消息内容的加密存储、通信日志的完整性验证以及异常行为的条件溯源机制，难以应对日志篡改、越权访问和纠纷追责等安全需求。

通用匿名通信系统。以 Tor (The Onion Router) 为代表的匿名通信系统通过多层加密和中间节点转发实现通信匿名性，在隐私保护领域具有重要影响。然而，这类系统的设计目标是通用互联网通信的匿名性，并未考虑外卖订单场景中订单认证、配送业务逻辑和平台治理等特殊需求。在 Tor 等系统中，通信参与方完全匿名，平台无法在发生纠纷时进行条件溯源，因此不适合直接应用于外卖订单通信场景。

学术研究现状。在学术研究层面，条件隐私保护 (Conditional Privacy-Preserving) 和可溯源匿名 (Traceable Anonymity) 已在车联网、电子投票、移动支付等领域得到较多研究。这些研究通常采用群签名、环签名、盲签名或零知识证明等密码学工具实现匿名性与可溯源性之间的平衡。然而，面向外卖订单即时通信场景的条件隐私保护方案研究尚处于起步阶段，现有方案多数停留在理论分析层面，缺少可运行的系统原型和端到端的安全机制闭环。

综上所述，现有方案在外卖订单通信安全方面存在三个主要不足：一是隐私保护措施碎片化，缺少覆盖身份匿名、消息保护和日志审计的系统化设计；二是匿名机制与平台治理之间缺乏平衡，要么过度暴露身份、要么完全不可溯源；三是多数方案缺少工程实现和实际验证。本作品旨在填补这一空白，设计并实现面向外卖订单通信场景的隐私认证与可信审计系统。

1.3 作品目标

针对上述安全问题与现有方案的不足，本作品旨在设计并实现一种面向外卖平台的隐私认证与可信审计系统——FoodShield。系统的核心安全目标如表1所示。

¹²参见美团规则中心”消费者权益保护”相关条款。

表 1: FoodShield 系统安全目标

编号	安全目标	定义
G1	身份匿名性	通信参与方在日常业务过程中无法获取对方真实身份，仅能看到匿名标识或订单相关信息。
G2	订单认证性	只有持有合法订单凭证的参与方才能进入对应订单的通信通道，攻击者无法伪造订单身份。
G3	消息保密性	通信消息在存储阶段经过加密处理，管理员和未授权方默认无法查看消息明文。
G4	日志完整性	通信日志的任何篡改、删除、插入或重排均可被检测，日志记录具备密码学完整性证明。
G5	条件可溯源	在投诉或审计场景下，管理员可在权限控制和审计记录约束下基于订单号恢复必要身份信息。

上述五个安全目标相互支撑，共同构成了”日常匿名、异常可溯源”的可控匿名安全模型。其中，G1 和 G2 保障日常通信中的隐私保护和认证安全，G3 和 G4 保障通信数据的保密性和可信性，G5 则在异常情况下为平台治理和纠纷处理提供追责能力。

1.4 我们的工作

为实现上述安全目标，我们设计并实现了 FoodShield 系统。该系统以国密算法为核心，围绕外卖订单通信场景构建了从匿名身份到可信审计的完整安全机制闭环。系统的技术结构主要包括四个层次：

- **匿名身份层**：通过基于 HMAC-SM3 的 PID 生成机制，将用户真实身份与通信身份解耦，实现日常通信中的身份匿名。
- **订单认证层**：通过基于 HMAC-SM3 的订单 Token 机制，验证通信参与方的订单合法性，防止伪造订单身份进入通信通道。
- **安全通信层**：通过 WebSocket 实现订单级实时通信，结合 SM4-CBC 加密存储

和 SM3 消息哈希，保障消息内容的保密性和可验证性。

- **可信审计层**：通过 Merkle Tree 日志完整性验证和条件溯源机制，实现通信日志的密码学完整性证明和异常情况下的受控溯源。

具体而言，我们的主要工作如下：

(1) **基于 HMAC-SM3 的 PID 匿名身份机制**。系统在用户注册时由平台服务器基于主密钥 K_{master} 、用户真实标识 $userID$ 和随机数 r 通过 HMAC-SM3 生成匿名身份标识 PID，即 $PID = \text{HMAC}(K_{master}, userID \parallel r)$ 。PID 在订单通信过程中替代真实身份参与认证和通信，骑手端和管理员端默认不直接展示 PID 原文，而是展示其 SM3 摘要值。该机制遵循最小知晓原则，在保障业务功能的前提下最大限度减少身份信息的暴露。

(2) **基于 HMAC-SM3 的订单 Token 认证机制**。用户创建订单后，服务器以订单号 $orderID$ 、匿名身份标识 PID 、时间戳 $timestamp$ 和 128 bit 随机数 $nonce$ 作为待认证消息，使用订单认证密钥 K_{order} 计算 HMAC-SM3 值作为订单 Token。用户进入订单通信通道时需提交订单号和 Token，服务器重新计算并验证 Token 的合法性、订单归属关系和时效性。时间戳和随机数的引入有效降低了 Token 被重放或预测的风险。

(3) **基于 SM4-CBC 的消息加密存储与 SM3 哈希审计**。用户与骑手之间的通信消息经服务器处理后，使用 SM4-CBC 模式进行加密存储，管理员端默认不展示消息明文，而是展示消息哈希、时间戳、订单号等审计信息。同时，系统对每条消息日志计算绑定订单号、消息序号、发送方角色、时间戳、密文摘要和前序哈希的 SM3 摘要作为 Merkle Tree 叶子节点，为日志完整性验证奠定基础。

(4) **基于 Merkle Tree 的日志完整性验证机制**。系统采用快照机制保存订单通信日志的 Merkle Root。当订单通信结束或管理员手动触发快照时，系统对当前订单的消息日志集合计算 Merkle Root 并写入快照表。后续验证时重新计算 Root 并与历史快照对比，若不一致则说明日志被篡改。在理想哈希假设下，攻击者伪造指定 SM3 摘要的复杂度约为 2^{256} ，寻找任意碰撞的复杂度约为 2^{128} ，为日志完整性提供了较高强度的密码学保障。

(5) **条件溯源与可信审计闭环**。当发生投诉或审计需求时，用户或骑手可基于订单号提交溯源申请，管理员经权限校验后执行条件溯源流程。溯源过程以订单号为入口，经 PID 映射恢复用户真实身份，且全程记录审计日志。溯源前必须先通过 Merkle Tree 完整性验证，确保溯源所依据的通信记录未被篡改。

系统的关键技术参数如表2所示。

表 2: FoodShield 系统关键技术参数

技术组件	参数	说明
SM3 密码杂凑	256 bit 输出	用于消息摘要、PID 哈希、Merkle 节点计算
SM4 对称加密	128 bit 密钥 / 128 bit 分组	CBC 模式，用于消息加密存储
HMAC-SM3	256 bit 输出	用于 PID 生成和订单 Token 计算
订单 Token	含 128 bit nonce	防重放设计，绑定订单号与匿名身份
Merkle Root	256 bit	日志完整性标识，通过快照机制保存
PID	HMAC 输出	匿名身份标识，与真实身份受控映射

1.5 应用前景

FoodShield 系统的设计理念和技术方案具有广阔的应用前景，主要体现在以下三个方面：

(1) 外卖行业隐私保护与合规治理。随着《个人信息保护法》和《数据安全法》的深入实施，外卖平台面临日益严格的隐私保护合规要求。FoodShield 提供的身份匿名、消息加密、日志完整性验证和条件溯源机制，可直接应用于外卖平台的订单通信系统，帮助平台在满足”最小必要原则”的前提下实现隐私保护与平台治理的平衡。系统中的虚拟号码脱敏、订单通信加密和审计日志等技术，为平台应对监管检查和用户投诉提供了技术支撑。

(2) 即时配送场景的安全通信扩展。FoodShield 的可控匿名通信模型不仅适用于外卖场景，也可推广至快递配送、跑腿代购、即时零售等更广泛的即时配送场景。这些场景具有与外卖类似的通信需求和安全风险——用户与配送员之间需要实时沟通，但用户不希望暴露真实身份。系统的模块化设计使得核心安全机制（PID 生成、Token 认证、Merkle 审计等）可作为独立组件集成到不同平台的业务流程中。

(3) 平台纠纷处理与数字证据可信化。在涉及配送纠纷、恶意骚扰或法律诉讼的场景中，通信记录的完整性和真实性是关键证据。FoodShield 的 Merkle Tree 日志完整性验证机制为通信记录提供了密码学完整性证明，使通信记录不仅能够被保存，而且能够被独立验证。这一机制可推广应用于电商平台客服聊天、在线医疗问诊、共享经济平台沟通等需要可信通信记录的场景，为数字时代的电子证据可信化提供技术方案。

预备知识

本章围绕 FoodShield 系统设计中所涉及的核心技术进行介绍，主要包括 HMAC 消息认证码、SM3 密码杂凑算法、SM4 对称加密算法、PID 匿名身份机制、WebSocket 实时通信机制、Merkle Tree 完整性验证机制以及条件溯源与可控匿名模型。上述技术共同支撑了本作品在外卖订单通信场景下的身份匿名、订单认证、消息保护、日志审计和异常追责等安全目标。其中，SM3 和 SM4 算法均为我国商用密码标准算法，分别遵循 GB/T 32905-2016 和 GB/T 32907-2016 国家标准；HMAC 机制遵循 RFC 2104 规范；WebSocket 协议遵循 RFC 6455 规范。

2.1 HMAC 消息认证码

HMAC (Hash-based Message Authentication Code) 是一种基于密码杂凑函数和共享密钥构造的消息认证码机制，由 Bellare、Canetti 和 Krawczyk 于 1996 年提出，并于 1997 年标准化为 RFC 2104¹³。与单纯的哈希运算不同，HMAC 在计算过程中引入了密钥，因此不仅能够检测消息内容是否被篡改，还能够验证消息是否由持有合法密钥的一方生成。HMAC 通常用于身份认证、接口鉴权、请求防伪造和数据完整性校验等场景。

设 H 表示密码杂凑函数， K 表示共享密钥， m 表示待认证消息，则 HMAC 的一般形式可以表示为：

$$\text{HMAC}(K, m) = H((K' \oplus \text{opad}) \parallel H((K' \oplus \text{ipad}) \parallel m)) \quad (1)$$

其中， K' 表示经过填充或压缩处理后的密钥（若密钥长度小于杂凑函数的分组长度，则在右侧填充零；若大于分组长度，则先对密钥计算一次杂凑值）， opad (outer pad) 和 ipad (inner pad) 分别表示外部填充值和内部填充值， $\parallel$ 表示字符串连接操作， $\oplus$ 表示按位异或。对于输出 256 bit 摘要的杂凑函数（如 SM3）， ipad 为字节 0x36 重复 32 次构成的 512 bit 序列， opad 为字节 0x5C 重复 32 次构成的 512 bit 序列。

HMAC 的安全性取决于底层杂凑函数的性质和密钥的保密性。在形式化安全分析中，HMAC 的安全性通常以**选择消息攻击下的存在性不可伪造性** (Existential Unforgeability under Chosen-Message Attack, EUF-CMA) 来刻画：对于概率多项式时

¹³Bellare, M., Canetti, R., Krawczyk, H. "Keyed-Hashing for Message Authentication." RFC 2104, IETF, 1997.

间的攻击者 $\mathcal{A}$, 若其不知道密钥 K , 但在可以查询任意消息 m_i 对应的 $\text{HMAC}(K, m_i)$ 的条件下, 仍然难以构造出一个未查询过的消息 m^* 的合法认证码 $\text{HMAC}(K, m^*)$, 则称该 HMAC 方案满足 EUF-CMA 安全性。当底层杂凑函数满足抗碰撞性和伪随机函数性质时, HMAC 的安全性可以归约到杂凑函数的安全性质上。

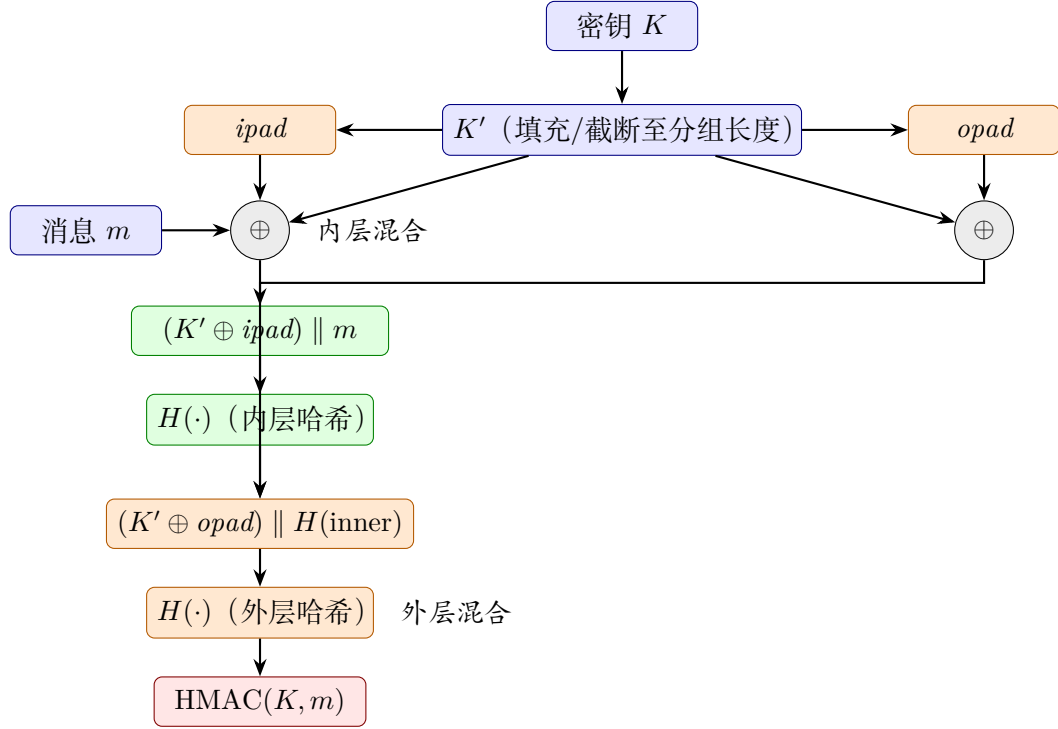


图 1: HMAC 双层嵌套哈希结构

在 FoodShield 系统中, HMAC 主要用于订单 Token 的生成与验证。用户在创建订单后, 平台服务器根据订单号、匿名身份标识、时间戳和随机数等字段生成订单认证 Token。用户进入订单通信通道时需要提交订单号和 Token, 服务器重新计算并比对 Token, 以判断用户是否为该订单的合法参与方。该机制使用户能够在不直接暴露真实身份的情况下证明自己拥有订单通信资格。

本系统中订单 Token 的抽象形式如下:

$$m_{\text{order}} = \text{orderID} \parallel \text{PID} \parallel \text{timestamp} \parallel \text{nonce} \quad (2)$$

$$\text{token} = \text{HMAC}(K_{\text{order}}, m_{\text{order}}) \quad (3)$$

其中, K_{order} 为订单认证密钥, orderID 为订单编号, PID 为用户匿名身份标识, timestamp 为时间戳, nonce 为 128 bit 随机数。通过引入时间戳和随机数, 可以降低 Token 被重放利用的风险——即使攻击者截获了某次通信的 Token, 由于时间戳

的时效性约束和随机数的不可预测性, 该 Token 也无法在其他订单或其他时间窗口中被成功复用。通过绑定订单号与匿名身份标识, 可以防止攻击者将一个订单的认证凭证迁移到其他订单中使用。

2.2 SM3 密码杂凑算法

SM3 是我国商用密码标准中的密码杂凑算法, 于 2016 年作为国家标准 GB/T 32905-2016 发布¹⁴。SM3 的输出长度固定为 256 bit, 分组长度为 512 bit, 采用 Merkle-Damgård 迭代结构, 共执行 64 轮压缩运算。SM3 主要用于数据完整性校验、数字签名、消息认证码构造和随机数生成等场景, 已成为我国金融、政务、电力等关键信息基础设施中广泛部署的国密算法之一。

设 m 表示输入消息, SM3 的输出可以表示为:

$$h = \text{SM3}(m) \quad (4)$$

其中, h 为长度为 256 bit 的消息摘要。SM3 的压缩函数将 256 bit 的中间状态值和 512 bit 的消息分组作为输入, 通过 64 轮混合运算 (包括消息扩展、布尔函数、模加运算和循环移位等操作) 输出新的 256 bit 状态值。由于摘要长度固定, SM3 适合用于对任意长度数据生成紧凑的完整性标识。

密码杂凑函数的安全性通常以以下三个性质来刻画:

- **抗原像性 (Preimage Resistance)**: 给定哈希值 h , 难以找到任意消息 m 使得 $\text{SM3}(m) = h$ 。对于 256 bit 输出的杂凑函数, 暴力搜索的复杂度为 $O(2^{256})$ 。
- **抗第二原像性 (Second Preimage Resistance)**: 给定消息 m_1 , 难以找到另一个不同的消息 $m_2 \neq m_1$ 使得 $\text{SM3}(m_1) = \text{SM3}(m_2)$ 。暴力搜索的复杂度为 $O(2^{256})$ 。
- **抗碰撞性 (Collision Resistance)**: 难以找到任意两个不同的消息 $m_1 \neq m_2$ 使得 $\text{SM3}(m_1) = \text{SM3}(m_2)$ 。根据生日攻击, 寻找碰撞的复杂度为 $O(2^{128})$ 。

上述三个性质为 FoodShield 系统的安全机制提供了理论基础: 抗原像性保证攻击者无法从消息摘要逆推原始消息内容; 抗第二原像性保证攻击者无法为已有消息构造具有相同摘要的替代消息; 抗碰撞性则是 Merkle Tree 完整性验证的安全基础

¹⁴GB/T 32905-2016 《信息安全技术 SM3 密码杂凑算法》, 国家标准化管理委员会, 2016 年 8 月 29 日发布, 2017 年 3 月 1 日实施。

——只要攻击者无法找到 SM3 碰撞，就无法在不改变 Merkle Root 的前提下篡改任意叶子节点。

在 FoodShield 系统中，SM3 主要用于三个方面。第一，SM3 可作为 HMAC 的底层杂凑函数，用于构造 HMAC-SM3 订单认证 Token。第二，系统可以对通信消息、密文内容、订单编号、发送方角色、时间戳等字段计算消息摘要，作为日志完整性验证的基础。第三，系统可以对 PID、设备标识等敏感字段进行摘要化处理，使管理员端在默认情况下只看到摘要值，而不直接接触敏感原始信息。

例如，对一条订单通信消息，可以将其摘要定义为：

$$message_{hash} = \text{SM3}(\text{orderId} \parallel \text{senderRole} \parallel \text{timestamp} \parallel \text{ciphertext}) \quad (5)$$

其中，*senderRole* 表示发送方角色，*ciphertext* 表示加密后的消息内容。只要消息内容、订单号、发送方角色或时间戳发生变化，重新计算得到的摘要值就会发生显著变化（雪崩效应）。因此，消息摘要可以作为后续 Merkle Tree 日志完整性验证的基本单元。

2.3 SM4 对称加密算法

SM4 是我国商用密码标准中的分组对称加密算法，于 2016 年作为国家标准 GB/T 32907-2016 发布¹⁵。SM4 的分组长度为 128 bit，密钥长度为 128 bit，采用 32 轮非平衡 Feistel 结构，每轮使用相同的轮函数但以不同的轮密钥进行运算。SM4 的加密和解密使用相同的算法结构，区别仅在于轮密钥的使用顺序相反。对称加密算法的特点是加密和解密使用相同密钥，具有计算效率高、适合批量数据加密等优点，常用于通信数据保护、数据库字段加密和文件加密等场景。

设 K 表示对称加密密钥， M 表示明文消息， C 表示密文消息，则 SM4 加密与解密过程可以抽象表示为：

$$C = \text{Enc}_K(M) \quad (6)$$

$$M = \text{Dec}_K(C) \quad (7)$$

¹⁵GB/T 32907-2016 《信息安全技术 SM4 分组密码算法》，国家标准化管理委员会，2016 年 8 月 29 日发布，2017 年 3 月 1 日实施。

SM4 的轮函数由以下组件构成：输入分组的 4 个 32 bit 字中，第一个字与其余三个字经轮函数 F 处理后异或，再与轮密钥结合，生成下一轮的输入。轮函数 F 中包含一个 8 bit 输入/8 bit 输出的 S 盒（非线性置换）和一个线性变换 L （由循环移位和异或组成）。密钥扩展算法使用与加密算法类似的结构，将 128 bit 主密钥扩展为 32 个 32 bit 轮密钥。

在实际系统中，SM4 通常需要结合工作模式使用，以处理长度大于一个分组的数据并增强安全性。常见的工作模式包括：

- **ECB (Electronic Codebook) 模式**：每个分组独立加密，相同明文分组产生相同密文，不适合加密结构化数据。
- **CBC (Cipher Block Chaining) 模式**：每个明文分组在加密前先与前一个密文分组异或，引入初始化向量 IV 使相同明文在不同加密过程中得到不同密文，安全性优于 ECB 模式。
- **CTR (Counter) 模式**：将递增计数器作为加密输入，输出与明文异或得到密文，支持并行加密。
- **GCM (Galois/Counter Mode) 模式**：在 CTR 模式基础上增加认证标签，同时提供加密和完整性保护。

以 CBC 模式为例，加密时需要引入初始化向量 IV ，使相同明文在不同加密过程中得到不同密文，从而降低明文模式泄露风险。其抽象形式如下：

$$C = \text{SM4-CBC-Enc}_K(IV, M) \quad (8)$$

具体而言，CBC 模式的加密过程为： $C_0 = IV$ ， $C_i = \text{Enc}_K(M_i \oplus C_{i-1})$ ，其中 M_i 和 C_i 分别表示第 i 个明文分组和密文分组。解密过程为： $M_i = \text{Dec}_K(C_i) \oplus C_{i-1}$ 。由于每个分组的加密都依赖于前一个密文分组，攻击者无法仅通过替换某个密文分组来篡改对应的明文而不影响后续分组的解密结果。

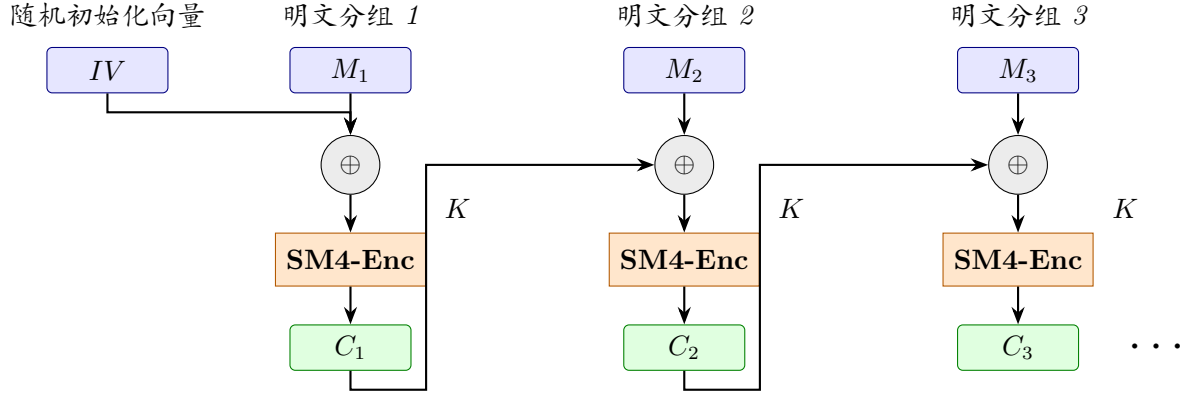


图 2: SM4-CBC 工作模式加密链示意图

在 FoodShield 系统中, SM4 主要用于订单通信消息的加密存储。用户与骑手之间的消息经过服务器处理后, 使用订单级会话密钥或平台侧加密密钥进行加密, 再写入数据库。管理员端默认不直接展示消息明文, 而是展示消息哈希、时间戳、订单号和 Merkle Root 等审计信息。这样可以降低数据库泄露或管理员越权查看造成的隐私风险。

需要说明的是, 本作品原型系统以可运行、可展示和安全机制闭环为主要目标。在实际部署环境中, 通信链路还应结合 HTTPS/TLS 保障传输安全, SM4 更多用于服务端存储阶段的消息内容保护。通过“传输层加密 + 存储层加密 + 日志哈希审计”的组合设计, 可以从多个层面降低订单通信数据泄露和篡改风险。

2.4 PID 匿名身份机制

PID (Pseudonymous Identifier) 即伪身份标识或匿名身份标识, 是隐私保护系统中常用的一种身份解耦机制。其核心思想是: 系统内部不直接使用真实用户身份参与通信和认证, 而是为用户生成一个与真实身份存在受控映射关系的匿名标识。在日常业务过程中, 通信参与方只能看到订单相关信息或匿名身份信息, 不能直接获得用户真实身份。

在 FoodShield 系统中, 用户注册后由平台服务器生成 PID。PID 由主密钥、用户真实标识、随机数和设备摘要等字段通过 HMAC 机制生成, 其抽象形式如下:

$$PID = \text{HMAC}(K_{\text{master}}, userID \parallel r) \quad (9)$$

其中, K_{master} 为平台主密钥, $userID$ 为用户真实身份标识, r 为随机数。引入随机数 r 的作用在于实现跨订单不可链接性 (Cross-Order Unlinkability): 即使同一用户在不同订单中使用 PID, 由于每次生成的随机数不同, 攻击者无法通过比较

PID 值来判断两个订单是否属于同一用户。这一性质对于防止跨订单的用户画像构建和身份关联攻击具有重要意义。

PID 的安全性可以从以下两个角度分析：

- **不可逆性**：由于 PID 基于 HMAC-SM3 生成，而 HMAC 的输出在不知道密钥 K_{master} 的情况下无法逆推出输入 $userID \parallel r$ ，因此攻击者即使获取了 PID，也无法直接恢复用户的真实身份。该性质基于 SM3 的抗原像性和 HMAC 的 EUF-CMA 安全性。
- **不可链接性**：由于每次 PID 生成引入了不同的随机数 r ，即使攻击者获取了同一用户的多个 PID，也无法判断这些 PID 是否指向同一用户。该性质基于 HMAC 输出的伪随机性。

PID 的作用不是取代用户登录身份，而是在订单通信过程中隐藏真实身份。用户在系统中仍然需要通过用户名、口令和设备识别等方式完成正常登录；登录成功后，系统在内部使用 PID 与订单进行绑定。骑手端只需要知道订单编号、订单状态和必要配送信息，不应看到用户真实身份，也不应直接看到 PID。管理员端默认也不直接展示 PID，而是展示经过摘要化处理的 PID 哈希值。

因此，FoodShield 中 PID 的设计原则可以概括为三点。第一，PID 是系统内部匿名标识，不作为普通前端页面中的公开身份展示。第二，PID 与真实身份之间的映射关系只能由平台服务器在受控条件下查询。第三，当发生投诉、恶意骚扰、纠纷处理或审计需求时，系统可以通过条件溯源流程恢复必要身份信息，从而实现隐私保护与责任追踪之间的平衡。

2.5 WebSocket 实时通信机制

WebSocket 是一种基于 TCP 的全双工通信协议，由 Fette 和 Melnikov 于 2011 年标准化为 RFC 6455¹⁶。与传统的 HTTP 通信采用“客户端请求、服务器响应”的模式不同，WebSocket 在客户端与服务器建立连接后，可以在同一连接上进行双向、全双工的实时数据交互，因此常用于在线聊天、实时通知、协同编辑和数据监控等场景。

WebSocket 通信的一般过程包括连接建立、身份认证、消息发送、消息转发和连接关闭五个阶段。在连接建立阶段，客户端首先向服务器发送 HTTP 升级请求 (Upgrade: websocket)，服务器返回 101 Switching Protocols 响应后双方建立 WebSocket

¹⁶Fette, I., Melnikov, A. "The WebSocket Protocol." RFC 6455, IETF, 2011.

长连接。此后，客户端和服务端可以在该连接上持续交换数据帧 (Data Frame)，而不需要为每条消息重新建立 HTTP 请求。这一机制显著降低了通信延迟和带宽开销，适合需要频繁消息交互的实时场景。

在 FoodShield 系统中，WebSocket 用于实现用户端与骑手端之间的订单级实时通信。系统以订单号为基本单位建立通信房间，每个订单对应一个独立的通信通道。用户或骑手进入通信房间前，服务器需要验证其身份状态和订单参与资格。对于用户端，服务器需要校验订单号和 Token；对于骑手端，服务器需要校验其是否为该订单绑定的配送方。只有验证通过的参与方才能加入对应订单房间。

订单通信过程可以抽象为：

$$Client \xrightarrow{orderID, credential} Server \quad (10)$$

$$Server \xrightarrow{verify(orderID, credential)} Room(orderID) \quad (11)$$

$$Message \xrightarrow{forward} User/Rider \quad (12)$$

其中，*credential* 表示订单认证凭证（即 Token）或骑手身份凭证。服务器在转发消息的同时，对消息进行加密存储、哈希计算和日志记录，使通信功能与安全审计机制形成联动。

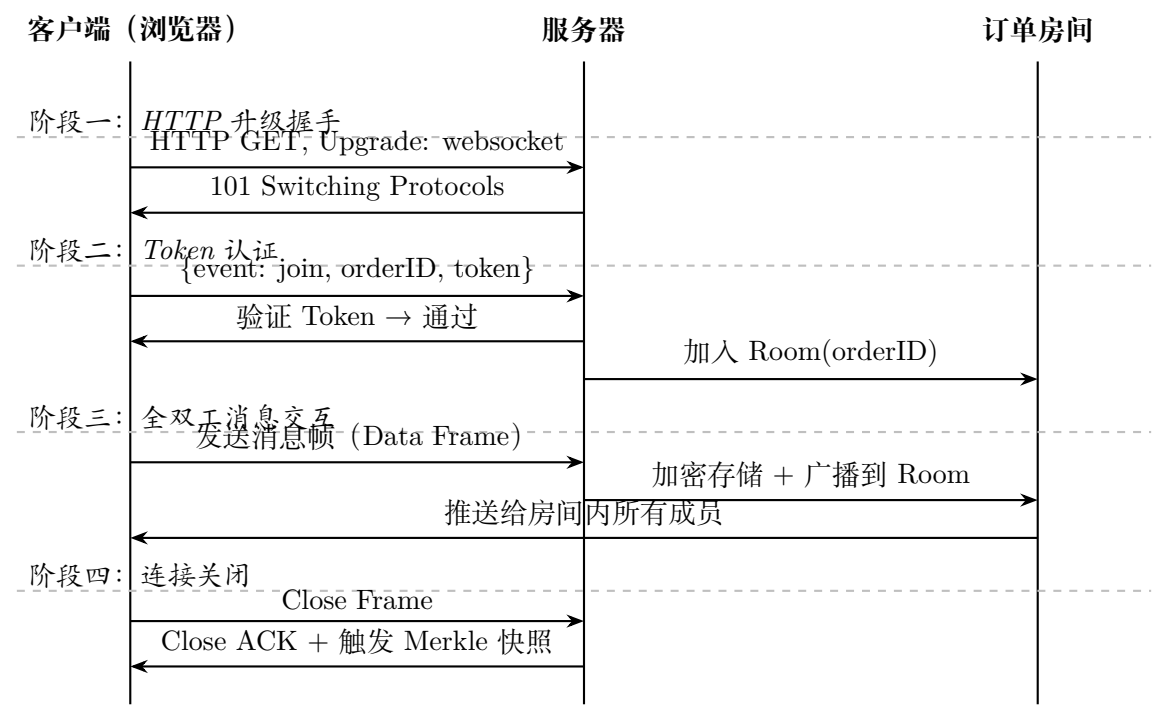


图 3: WebSocket 握手及订单通信时序示意图

需要指出的是，WebSocket 协议本身主要解决实时通信的连接管理问题，并不直接提供消息加密、身份认证或日志完整性保护等安全功能。因此，在实际应用中，WebSocket 应结合 TLS 形成 WSS (WebSocket Secure) 安全连接，以防止通信内容在传输过程中被窃听或篡改。本作品在系统设计中将 WebSocket 作为实时消息通道，将 Token 认证、消息加密、哈希审计和权限控制作为安全增强机制，从而避免将普通聊天功能误认为完整安全机制。

2.6 Merkle Tree 完整性验证

Merkle Tree 是一种基于哈希函数构造的树形数据完整性验证结构，又称哈希树，由 Ralph Merkle 于 1979 年提出¹⁷。其基本思想是：先对每个数据块计算哈希值，作为叶子节点；再将相邻节点哈希拼接后继续计算父节点哈希；最终逐层向上计算得到根节点哈希，即 Merkle Root。只要任意一个叶子节点对应的数据发生变化，最终计算得到的 Merkle Root 就会发生变化。因此，Merkle Tree 广泛应用于区块链、文件完整性验证、日志审计和分布式存储等场景。

设系统中共有 n 条消息日志，分别为 $m_1, m_2, \dots, m_n$ ，对应叶子节点可以表示为：

¹⁷Merkle, R. C. "A Certified Digital Signature." In *Advances in Cryptology – CRYPTO '89 Proceedings*, Lecture Notes in Computer Science, vol. 435, pp. 218–238, Springer, 1989. 原始构思参见 Merkle, R. C. "Secrecy, Authentication, and Public Key Systems." Technical Report, Stanford University, 1979.

$$leaf_i = H(m_i), \quad i = 1, 2, \dots, n \quad (13)$$

相邻两个叶子节点进一步计算父节点：

$$parent_{i,j} = H(leaf_i \parallel leaf_j) \quad (14)$$

逐层向上递归计算，最终得到根节点：

$$root = \text{MerkleRoot}(leaf_1, leaf_2, \dots, leaf_n) \quad (15)$$

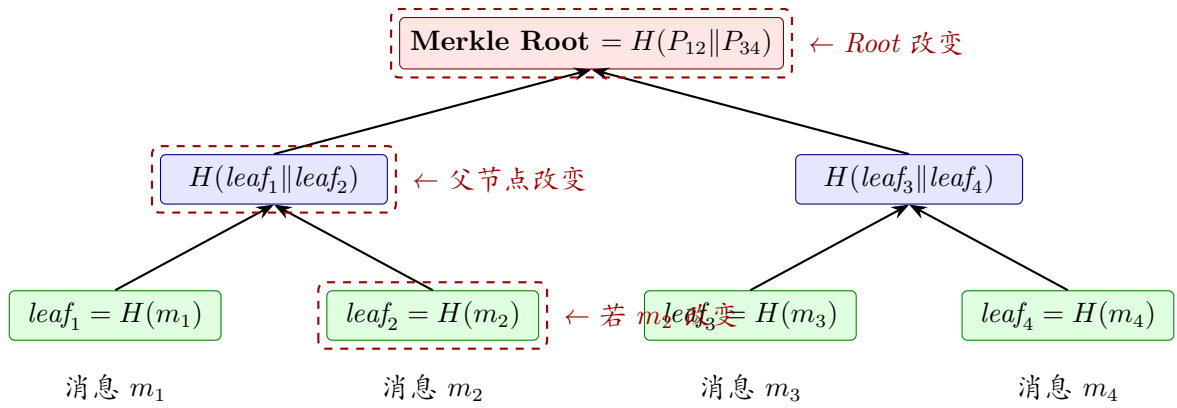


图 4: Merkle Tree 结构示意图（任意叶子变化均导致 Root 改变）

Merkle Tree 的一个重要优势是支持高效的**包含证明** (Inclusion Proof)：要验证某个叶子节点 $leaf_i$ 是否包含在以 $root$ 为根的 Merkle Tree 中，验证者只需知道从 $leaf_i$ 到 $root$ 路径上的兄弟节点哈希值（即验证路径），即可通过 $O(\log n)$ 次哈希计算完成验证，而无需获取全部 n 个叶子节点。这一性质使得 Merkle Tree 在大规模数据集的完整性验证中具有显著的效率优势。

在 FoodShield 系统中，Merkle Tree 用于订单通信日志的完整性验证。系统并不直接将明文消息作为叶子节点，而是将与消息相关的摘要信息作为叶子节点输入。为了绑定订单上下文、发送方角色、消息顺序和密文内容，本系统中单条消息日志的叶子节点可以抽象定义为：

$$leaf_i = \text{SM3}(\text{orderId} \parallel \text{msgSeq} \parallel \text{senderRole} \parallel \text{timestamp} \parallel \text{ciphertextHash} \parallel \text{prevHash}) \quad (16)$$

其中，各字段含义如下：

- *orderId*: 订单编号, 将叶子节点绑定到特定订单, 防止跨订单拼接攻击。
- *msgSeq*: 消息序号, 记录消息在订单通信中的顺序, 可检测消息重排和删除。
- *senderRole*: 发送方角色 (用户或骑手), 防止发送方身份伪造。
- *timestamp*: 发送时间戳, 提供时间维度的可验证性。
- *ciphertextHash*: 消息密文摘要, 绑定消息内容, 检测内容篡改。
- *prevHash*: 前一条消息日志的摘要, 形成链式结构, 可检测消息插入和删除。

该设计通过将多个上下文字段绑定到叶子节点中, 能够同时检测消息内容篡改、消息顺序调整、消息插入和消息删除等异常情况。与仅对密文计算哈希的简单方案相比, 本方案的叶子节点结构提供了更细粒度的完整性保护。

为了保证 Merkle Root 的可验证性, 系统采用快照机制保存 Root。每当订单通信结束、管理员手动生成审计快照或消息数量达到设定阈值时, 系统对当前订单的消息日志集合计算 Merkle Root, 并将订单号、消息数量、Root 值和快照时间写入日志快照表。后续进行完整性验证时, 系统重新读取订单消息日志并计算新的 Root, 与历史快照中的 Root 进行比较。如果二者一致, 说明当前日志集合与快照生成时保持一致; 如果二者不一致, 则说明日志可能被修改、删除、插入或重排。

因此, Merkle Tree 在本系统中的作用不是加密消息内容, 而是提供日志完整性证明。它可以使平台在发生纠纷时证明通信记录是否被篡改, 从而提升订单通信记录的可信度和审计价值。

2.7 条件溯源与可控匿名模型

匿名机制能够保护用户隐私, 但完全匿名也可能导致恶意行为难以追责。在外卖订单通信场景中, 用户和骑手之间可能发生恶意骚扰、虚假投诉、配送纠纷或违规沟通等情况。如果系统只强调匿名而不保留治理能力, 平台将难以处理异常事件; 如果系统默认暴露真实身份, 则又会削弱隐私保护效果。因此, 本作品采用条件溯源与可控匿名相结合的设计思路。

可控匿名 (Controllable Anonymity) 是指系统在正常业务流程中隐藏用户真实身份, 而在满足特定条件时, 由具备权限的管理方按照审计流程恢复必要身份信息。该模型强调“日常匿名、异常可追责”。可控匿名区别于完全匿名 (如 Tor) 和完全实名两种极端模式, 在隐私保护与责任追踪之间寻求平衡。

在 FoodShield 系统中，普通通信状态下，骑手端无法看到用户真实身份，也无法看到用户 PID；管理员端默认只查看订单摘要、消息哈希、Merkle Root 和完整性验证结果。当发生投诉、纠纷或平台审计需求时，用户或骑手可以基于订单号提交溯源申请，管理员经过身份认证和权限校验后，才能触发条件溯源流程。

条件溯源流程可以抽象为：

$$orderID \xrightarrow{\text{verify-integrity}} PID \xrightarrow{\text{lookup}} userID \quad (17)$$

其中，*orderID* 是业务入口，*PID* 是系统内部匿名标识，*userID* 是真实用户身份标识。系统不鼓励管理员直接通过 *PID* 发起溯源，而是以订单号作为溯源入口。这种方式更符合外卖平台的真实业务逻辑（投诉和纠纷通常以订单为单位发起），也可以降低 *PID* 被滥用或过度暴露的风险。

条件溯源流程包含两个关键安全约束：

- **完整性前置校验：**在执行溯源之前，系统必须先对目标订单的通信日志进行 Merkle Tree 完整性验证。只有当日志完整性验证通过时，才允许继续溯源流程。这一约束确保了溯源所依据的通信记录未被篡改，防止攻击者通过篡改日志来误导溯源结果。
- **关键词条件触发：**溯源过程通常由投诉或举报触发，系统根据投诉内容中的关键词进行命中匹配，确认是否存在异常通信行为。只有当关键词命中且完整性校验通过时，才执行从 *orderID* 到 *userID* 的身份映射。这一双重门槛机制防止管理员滥用溯源权限进行无依据的身份查询。

在条件溯源过程中，系统应记录管理员的关键操作，包括登录行为、查看订单摘要、执行完整性验证、确认溯源申请和查询身份映射等。每一次溯源操作都应写入审计日志，记录操作者、操作时间、目标订单、溯源理由和操作结果。通过这种方式，系统不仅可以追踪用户或骑手的异常行为，也可以约束管理员权限，避免审计能力本身成为新的隐私风险。

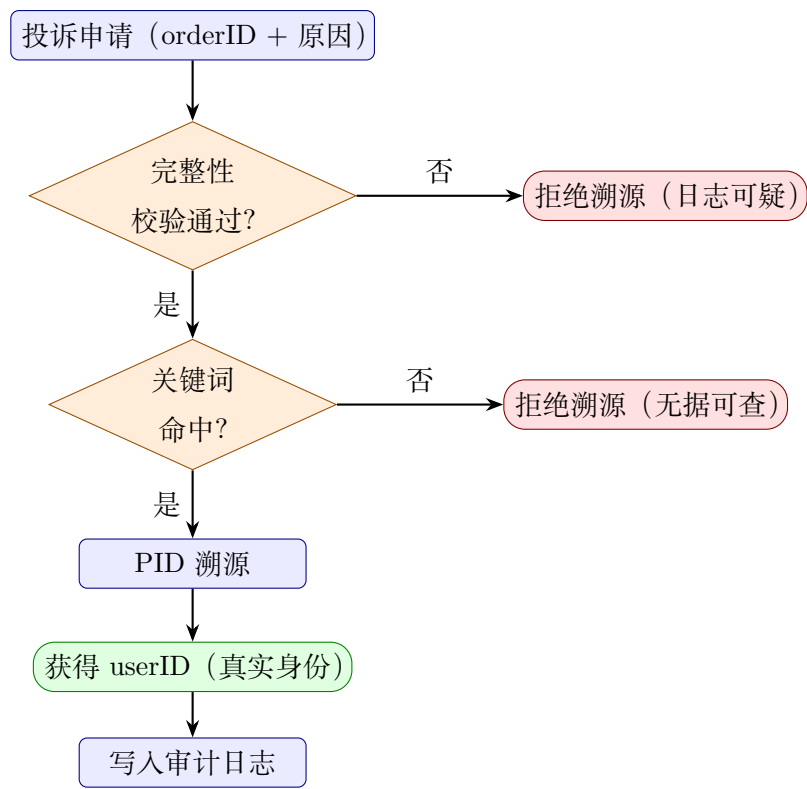


图 5: 条件溯源概念流程（预备知识层）

综上，条件溯源与可控匿名模型是 FoodShield 系统区别于普通匿名通信系统的重要设计。它既避免了普通外卖聊天系统中过度暴露身份的问题，也避免了完全匿名系统中责任主体无法追踪的问题，从而在隐私保护、订单认证和平台治理之间形成平衡。

系统设计

3.1 系统总体方案

FoodShield 是一个面向外卖订单通信场景的隐私认证与可信审计系统。系统以外卖平台中用户与骑手之间的订单沟通为基本应用场景，围绕身份信息暴露、订单通信越权、聊天记录篡改和纠纷追责困难等问题，设计了集匿名身份、订单认证、加密通信、日志完整性验证和条件溯源于一体的安全通信方案。

传统外卖订单通信系统通常更关注业务连通性，即用户和骑手能否完成消息交互，而对通信过程中的安全边界关注不足。例如，骑手端可能接触到超出配送所需范围的用户信息，普通订单号可能被误用或伪造，管理员端可能拥有过大的信息查看权限，历史通信记录也可能在纠纷处理前被修改、删除或重排。针对上述问题，FoodShield 将“订单”作为系统安全控制的核心索引，将用户身份、订单资格、通信通道和审计日志统一绑定到订单生命周期中，从而在业务可用性的基础上增加隐私保护和可信审计能力。

系统总体设计遵循“日常匿名、订单认证、日志可信、异常可溯源”的原则。在日常通信过程中，系统不向骑手端暴露用户真实身份，也不向骑手端展示用户 PID；用户注册阶段不再是简单输入用户名生成匿名标识，而是采用“用户名、口令、机器识别”相结合的方式，降低机器批量注册和匿名身份滥用风险。用户创建订单后，系统将订单号、用户匿名身份、骑手身份和订单状态进行绑定，并生成基于 HMAC-SM3 的订单 Token。用户进入订单通信通道前，需要提交订单号和 Token，服务器验证通过后才允许其加入对应订单房间。

通信过程中，用户端与骑手端通过订单级 WebSocket 通道进行实时通信。系统对通信消息进行加密存储，并对订单号、发送方角色、时间戳、消息序号和密文摘要等字段计算消息哈希。审计阶段，系统将消息摘要作为 Merkle Tree 叶子节点，生成 Merkle Root 并通过快照机制保存。后续若通信记录被修改、删除、插入或重排，重新计算得到的 Root 将与历史快照不一致，从而能够检测日志篡改行为。

当发生投诉、恶意骚扰、虚假争议或平台审计需求时，系统支持用户端和骑手端基于订单号发起条件溯源申请。管理员登录后只能默认查看订单摘要、消息哈希、Merkle Root 和审计记录，不直接展示通信明文内容；只有在满足权限校验、审计理由和操作记录要求后，管理员才能基于订单号触发条件溯源。该设计避免了直接通过 PID 任意查询真实身份的问题，使系统在保护用户隐私的同时保留必要的平台治理能力。

从功能组成上看，FoodShield 主要包括以下核心模块：

1. **用户注册与身份初始化模块**：负责用户注册、口令认证、机器识别、PID 生成和匿名身份初始化，避免系统仅具有标识而缺少真实认证流程。
2. **匿名身份管理模块**：负责生成和维护用户 PID，并保存 PID 与真实身份之间的受控映射关系。PID 默认不在普通前端页面展示，骑手端不可见。
3. **订单 Token 认证模块**：负责根据订单号、PID、时间戳和随机数生成订单认证 Token，并在用户进入通信通道前进行合法性、归属关系和时效性验证。
4. **订单级实时通信模块**：负责用户端与骑手端之间的 WebSocket 通信、订单房间管理、消息转发、订单历史记录和订单搜索。
5. **消息保护与日志审计模块**：负责消息加密存储、SM3 摘要生成、Merkle Tree 构建、Merkle Root 快照保存和日志完整性验证。
6. **条件溯源与管理审计模块**：负责投诉申请、管理员权限校验、基于订单号的条件溯源和管理员操作审计记录。

在技术实现上，系统采用 Python Flask 作为后端服务框架，使用 SQLite 存储用户、订单、消息和审计数据，使用 WebSocket 实现实时通信。在密码学机制方面，系统使用 HMAC-SM3 构造订单认证 Token，使用 SM4 对通信消息进行加密存储，使用 SM3 生成消息摘要，并使用 Merkle Tree 对通信日志进行完整性验证。上述机制共同构成了 FoodShield 的安全基础，使其能够在外卖订单通信这一具体场景中兼顾隐私保护、业务可用性和平台治理能力。

3.2 系统参与方与信任边界

FoodShield 系统涉及用户端、骑手端、平台服务器、管理员端和审计日志系统五类主要参与方。不同参与方具有不同的业务权限和信息可见范围。系统通过权限隔离、字段隐藏和数据最小化原则限制敏感信息暴露，避免普通通信功能演变为身份泄露通道。

表 3: 系统主要参与方与权限边界

参与方	主要功能	权限与隐私边界
用户端	注册登录；创建订单；查看订单历史；订单搜索；添加备注标签；发起投诉申请。	仅可查看本人订单与本人通信内容；PID 作为系统内部匿名标识，默认不在普通页面展示；用户不直接接触真实身份与 PID 的映射关系。
骑手端	查看分配订单；搜索配送任务；进入订单通信；处理配送异常；发起投诉申请。	仅可查看订单编号、订单状态、必要配送信息和通信窗口；不可见用户真实身份；不可见用户 PID；不可见用户备注和标签原文。
平台服务器	用户认证；机器识别；PID 生成；订单绑定；Token 验证；消息转发；加密存储；条件溯源。	作为核心安全控制单元，维护必要的身份映射和订单状态；不向普通业务端暴露真实身份映射；敏感操作需要权限控制与审计记录。
管理员端	管理员登录；订单检索；日志验证；处理溯源申请；查看审计结果。	默认只查看订单摘要、消息哈希、Merkle Root、日志验证结果和溯源申请状态；默认不展示通信明文、用户备注和标签原文；不能直接按 PID 任意溯源。
审计日志系统	保存消息摘要；保存 Merkle Root 快照；记录管理员操作；支持日志完整性验证。	不作为明文消息查询入口；主要用于检测日志篡改，并为纠纷处理和管理员行为追踪提供可信依据。

从信任关系上看，FoodShield 采用平台可控匿名模型。平台服务器被视为系统中的基础可信实体，负责维护真实身份与 PID 之间的映射关系；用户和骑手彼此之间不完全信任，系统需要防止双方获取超过订单通信所需范围的敏感信息；管理员具有较高权限，但管理员行为也不能完全无约束，因此系统需要记录管理员的登录、

查询、验证和溯源操作；外部攻击者不被信任，可能尝试伪造订单身份、重放 Token、篡改通信日志或越权访问管理员接口。

系统的主要信任边界包括以下几个方面：

1. **用户端与骑手端之间的边界**：用户与骑手只应围绕订单配送进行通信。骑手端不应获得用户真实身份和 PID，用户端也不应获得骑手端超出配送所需范围的敏感信息。
2. **普通业务端与管理端之间的边界**：用户端和骑手端不能访问管理员接口；管理员端访问审计功能前必须完成身份认证。
3. **平台服务器与数据库之间的边界**：数据库保存订单、消息和审计数据，但通信明文不应直接裸露存储。消息内容应加密保存，消息摘要参与完整性验证。
4. **管理员权限与溯源能力之间的边界**：管理员不能任意根据 PID 发起溯源，而应基于订单号、投诉理由和审计需求触发条件溯源，并将操作写入审计日志。
5. **备注标签与审计数据之间的边界**：用户可为订单添加备注或标签以便历史订单管理和搜索，但管理员端默认不展示备注或标签的具体内容，避免审计权限扩大为隐私查看权限。
6. **日志数据与业务数据之间的边界**：日志审计系统主要保存消息摘要、Merkle Root 和操作记录，用于验证数据是否被篡改，而不是作为普通业务查询明文消息的入口。

通过上述信任边界划分，FoodShield 将用户隐私保护、订单通信业务和平台治理能力进行分层隔离。不同参与方只能访问其业务所需的最小信息集合，从而降低身份暴露、越权访问、日志篡改和审计权限滥用风险。

3.3 威胁模型

FoodShield 的威胁模型围绕外卖订单通信场景中的身份伪造、隐私泄露、日志篡改、管理员越权和匿名身份滥用等问题展开。系统假设攻击者具有一定的网络访问能力和业务接口调用能力，可能通过伪造请求参数、重放认证凭证、篡改数据库记录、批量注册账号或越权访问接口等方式破坏系统安全性。

本系统重点考虑以下几类威胁：

1. **订单身份伪造攻击**：攻击者可能尝试构造虚假的订单号或 Token，以非订单参与方身份进入用户与骑手之间的订单通信通道。如果系统仅依赖订单号作为入口，则订单号一旦泄露，攻击者可能冒充合法用户或骑手参与通信。
2. **Token 重放攻击**：攻击者可能截获某次合法订单认证请求中的 Token，并在之后重复使用该 Token 尝试进入通信通道。如果 Token 不包含时间戳、随机数或有效期限限制，则存在被重复利用的风险。
3. **机器批量注册攻击**：攻击者可能使用脚本批量注册账号，生成大量匿名身份并发起垃圾订单或骚扰通信。如果注册阶段仅输入用户名并直接生成 PID，则系统实际上只有标识生成过程，而缺少有效认证和反滥用能力。
4. **用户身份暴露风险**：在普通外卖通信模式下，用户真实身份、联系方式、地址备注等信息可能被骑手端或管理员端过度接触。恶意骑手可能利用固定身份标识进行跨订单关联，甚至造成骚扰或隐私泄露。
5. **通信日志篡改攻击**：攻击者或内部恶意人员可能尝试修改、删除、插入或重排历史通信记录，以影响订单纠纷处理结果。如果系统仅保存普通数据库记录，而缺少完整性验证机制，则难以证明记录是否保持原始状态。
6. **管理员越权访问风险**：管理员具有较高审计权限，如果缺少权限控制和审计记录，管理员可能在无投诉、无异常或无授权的情况下查看敏感数据或执行溯源操作，造成二次隐私泄露。
7. **订单备注与标签泄露风险**：订单备注或标签可能包含用户生活习惯、地址细节、偏好信息等隐私内容。如果管理员端默认展示这些内容，可能导致审计功能扩大为隐私查看功能。

针对上述威胁，FoodShield 采用多层防护机制。对于订单身份伪造问题，系统使用 HMAC-SM3 生成订单 Token，将订单号、PID、时间戳和随机数绑定到同一认证凭证中；对于 Token 重放风险，系统引入时间戳和随机数，并设置 Token 有效期；对于机器注册攻击，系统在注册阶段引入口令认证和设备识别，必要时结合注册频率限制；对于身份暴露风险，系统通过 PID 匿名身份机制隐藏真实用户身份，并限制骑手端和管理员端的可见字段；对于通信日志篡改问题，系统使用 SM3 消息摘要和 Merkle Tree 完整性验证机制检测历史记录是否被修改；对于管理员越权问题，系统要求管理员登录认证，并将关键操作写入审计日志；对于备注标签泄露问题，管理员端默认不展示用户备注或标签原文。

需要说明的是，本系统不追求对平台服务器的绝对匿名。平台服务器作为业务和安全控制中心，需要维护用户真实身份与 PID 的映射关系，以便在投诉、纠纷或审计场景下进行条件溯源。因此，FoodShield 采用的是”平台可控匿名”模型，而不是完全匿名模型。该模型的目标是在日常通信中对骑手、普通用户和外部攻击者隐藏真实身份，同时在满足审计条件时保留必要的责任追踪能力。

3.4 安全目标

结合外卖订单通信场景和上述威胁模型，FoodShield 的安全目标主要包括匿名性、认证性、机密性、完整性、可追责性、可审计性和抗滥用能力。系统通过不同安全机制分别支撑上述目标，使外卖订单通信过程不仅能够完成业务沟通，而且能够满足基本的信息安全要求。

表 4: FoodShield 系统安全目标与对应机制

安全目标	防护对象	对应机制
匿名性	用户真实身份、用户 PID、跨订单关联信息	PID 内部化；骑手端不可见 PID；前端字段最小化展示
认证性	订单通信入口、订单参与资格	HMAC-SM3 订单 Token；绑定 orderID、PID、timestamp、nonce
机密性	订单聊天内容、数据库消息记录	WebSocket/WSS 传输保护；SM4 消息加密存储；管理员端默认不看明文
完整性	历史通信记录、消息顺序、消息数量	SM3 消息摘要；Merkle Tree；Merkle Root 快照比对
可追责性	投诉纠纷、恶意骚扰、异常订单	用户端与骑手端均可按 orderID 发起申请；管理员条件溯源
可审计性	管理员查询、验证、溯源等高权限操作	管理员认证；audit_logs 记录操作时间、目标订单和操作结果
抗滥用能力	机器注册、垃圾订单、匿名身份滥用	用户名与口令认证；机器识别；注册频率限制
隐私最小化	用户备注、标签、通信明文、身份映射关系	管理员端仅展示订单摘要、消息哈希、Merkle Root 和验证状态

其中，匿名性和可追责性是本系统设计中的一组核心平衡目标。完全匿名虽然能够增强隐私保护，但可能导致恶意行为难以治理；完全实名虽然便于追责，但会增加用户身份暴露风险。因此，FoodShield 采用可控匿名设计：日常通信中隐藏真实身份，异常场景下通过管理员权限校验和审计记录完成条件溯源。

认证性是系统防止越权通信的关键。用户进入订单通信通道前，需要提交订单号和订单 Token，服务器根据订单绑定关系重新计算 Token 并判断其合法性。由于 Token 由订单号、PID、时间戳和随机数共同参与生成，攻击者在不知道订单认证密钥的情况下难以伪造合法凭证。

完整性是系统可信审计能力的基础。FoodShield 不仅保存通信记录，还对每条消息生成摘要，并将消息摘要组织为 Merkle Tree。系统通过保存 Merkle Root 快照，使后续审计过程中能够验证历史通信记录是否发生变化。如果任意消息内容、消息顺序或消息数量被修改，重新计算的 Root 将与历史快照不一致，从而暴露篡改行为。

可审计性主要用于约束管理员权限。管理员虽然可以处理异常订单和执行溯源，但其操作必须被记录。系统通过审计日志保存管理员身份、操作时间、目标订单、操作类型和操作结果，使管理员行为具备可追踪性，从而降低审计能力本身带来的隐私风险。

3.5 系统总体架构

FoodShield 采用多端协同的分层架构，整体上可以划分为表现层、业务服务层、安全机制层、数据存储层和审计验证层。表现层包括用户端、骑手端和管理员端；业务服务层负责注册登录、创建订单、订单历史、订单搜索、备注标签、订单认证、消息转发、投诉申请等功能；安全机制层提供 PID 生成、Token 验证、SM4 加密、SM3 摘要和 Merkle Tree 构建等能力；数据存储层保存用户、骑手、订单、消息、快照和审计日志等数据；审计验证层负责日志完整性验证、Root 快照比对、条件溯源记录和两端摘要一致性增强。

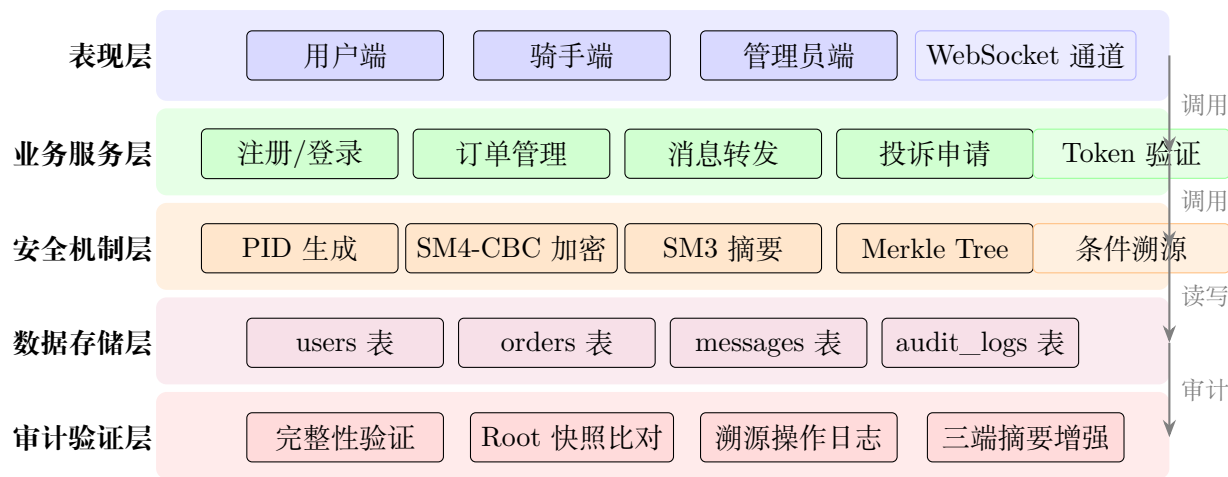


图 6: FoodShield 系统总体架构分层图

系统总体架构可以概括如下：

- 1. 用户端：**用户端提供用户注册、登录、创建订单、查看订单历史、搜索订单、添加备注标签、进入订单通信和提交投诉申请等功能。用户完成注册后，系统在内部生成 PID，并在订单创建时将 PID 与订单号进行绑定。用户进入通信通道前，需要提交订单号和 Token 完成订单认证。
- 2. 骑手端：**骑手端提供骑手登录、查看分配订单、根据订单号搜索订单、进入订单通信和提交异常申请等功能。骑手端只显示订单相关必要信息，不显示用户真实身份和 PID，避免骑手通过长期标识进行跨订单关联。
- 3. 平台服务器：**平台服务器是系统核心部分，负责接收用户端、骑手端和管理员端请求，并调用不同安全模块完成业务处理。平台服务器内部包括用户注册与机器识别模块、匿名身份管理模块、订单认证模块、消息转发模块、消息加密存储模块、日志审计模块和条件溯源模块。
- 4. 管理员端：**管理员端用于平台审计和异常处理。管理员登录后可以根据订单号检索订单摘要，查看消息哈希和 Merkle Root，执行日志完整性验证，处理用户端或骑手端提交的溯源申请。管理员端默认不展示通信明文内容，也不展示用户备注或标签原文。
- 5. 审计日志系统：**审计日志系统保存通信消息摘要、Merkle Root 快照和管理员操作日志。系统在订单通信过程中持续生成消息哈希，并在订单结束或管理员触发快照时计算 Merkle Root。后续验证时，系统重新计算 Root 并与快照值对比，以判断日志是否被篡改。

6. **三端摘要一致性增强机制**: 在订单通信结束时, 系统可将订单通信摘要或 Merkle Root 摘要分别留存在用户端、骑手端和平台端。后续审计时, 若攻击者试图篡改平台侧数据库记录, 则需要同时修改三端摘要才能伪造一致结果, 从而提高日志篡改成本。

系统的基本业务流程如下。首先, 用户完成注册和登录, 注册阶段包含用户名、口令和机器识别信息, 平台服务器生成用户 PID, 并保存 PID 与真实身份之间的受控映射关系。其次, 用户创建订单, 服务器生成订单号并将订单与用户 PID、骑手身份、订单备注和订单状态进行绑定, 同时生成订单 Token。随后, 用户进入订单通信页面时提交订单号和 Token, 服务器验证通过后允许用户加入对应 WebSocket 通信房间; 骑手端经过身份验证后进入同一订单房间。通信过程中, 平台服务器负责消息转发、消息加密存储和消息哈希计算。订单完成或管理员生成审计快照时, 系统根据消息摘要构建 Merkle Tree 并保存 Merkle Root。若后续发生投诉或纠纷, 用户或骑手可基于订单号发起申请, 管理员经权限验证后查看审计摘要、验证日志完整性, 并在必要时执行条件溯源。

在架构设计上, FoodShield 的关键特点在于将业务流程和安全机制进行绑定。订单不是单纯的业务编号, 而是认证、通信、日志和溯源的核心索引; PID 不是公开展示的用户身份, 而是内部匿名绑定标识; Token 不是普通随机字符串, 而是基于 HMAC-SM3 的订单认证凭证; 消息记录不是普通数据库文本, 而是加密存储并参与 Merkle Tree 完整性验证的审计对象; 管理员端不是明文查看入口, 而是哈希摘要、Root 验证和条件溯源的受控审计入口。通过这种设计, 系统能够围绕订单这一核心业务对象建立完整的隐私保护与可信审计闭环。

3.6 数据库设计

FoodShield 使用 SQLite 作为数据存储后端, 数据库共设计四张核心表: `users` (用户表)、`orders` (订单表)、`messages` (消息表) 和 `audit_logs` (审计日志表)。各表字段的设计均遵循“最小必要原则”, 避免将超出业务所需的敏感信息明文保存在数据库中。

用户表 (`users`)

用户表存储用户的注册信息与匿名身份标识, 字段设计如表 5 所示。

表 5: users 表字段说明

字段名	类型	说明	安全设计意义
id	INTEGER	自增主键	内部索引，不对外暴露
username	TEXT UNIQUE	用户名	用于登录认证
pid	TEXT UNIQUE	匿名身份标识 (PID)	隐藏真实 id，用于通信和溯源
pid_r	TEXT	PID 生成随机数 r	仅服务端保存，用于条件溯源时重算 PID
password_hash	TEXT	口令哈希值	SM3(salt password)，不存明文口令
salt	TEXT	随机盐值	防彩虹表攻击，每用户独立随机
created_at	TIMESTAMP	注册时间	用于审计和频率限制参考

订单表 (orders)

订单表存储订单生命周期数据，字段设计如表 6 所示。

表 6: orders 表字段说明

字段名	类型	说明	安全设计意义
id	INTEGER	自增主键	内部索引
order_id	TEXT UNIQUE	UUID 订单号	随机生成，防顺序枚举
user_id	INTEGER	关联用户内部 id	外键引用 users.id，不暴露 PID
token	TEXT	订单 Token	HMAC-SM3 认证凭证，入房校验用
token_timestamp	TEXT	Token 生成时间戳	用于 Token 有效期校验
status	TEXT	订单状态	枚举值： created/taken/delivering/completed/cancelled
note	TEXT	用户备注/标签	对骑手端和管理员端隐藏，仅用户自查
created_at	TIMESTAMP	订单创建时间	用于历史查询与审计

消息表 (messages)

消息表存储通信记录，字段设计如表 7 所示。

表 7: messages 表字段说明

字段名	类型	说明	安全设计意义
id	INTEGER	自增主键	内部索引，也用于消息顺序
msg_id	TEXT UNIQUE	UUID 消息号	全局唯一，防重复提交
order_id	TEXT	关联订单号	外键引用 orders.order_id
sender_pid	TEXT	发送方 PID	不暴露真实用户名
role	TEXT	发送方角色	枚举：user/rider/admin/system
content	TEXT	消息密文	SM4-CBC 加密存储，不存明文
message_hash	TEXT	消息摘要	SM3 对明文字段联合计算，用于 Merkle Tree 叶子节点
timestamp	TEXT	消息时间戳	ISO 8601 格式，参与哈希计算
created_at	TIMESTAMP	写入时间	与 timestamp 一致性校验参考

审计日志表 (audit_logs)

审计日志表存储 Merkle Root 快照和管理员操作记录，字段设计如表 8 所示。

表 8: audit_logs 表字段说明

字段名	类型	说明	安全设计意义
id	INTEGER	自增主键	内部索引
order_id	TEXT	关联订单号	可为 NULL（登录等全局操作）
action	TEXT	操作类型	枚举： MERKLE_ROOT_UPDATED / VERIFY_OK / VERIFY_FAIL / TRACE_SUCCESS 等
detail	TEXT	操作详情（JSON）	记录消息数、不匹配哈希列表、管理员用户名等
merkle_root	TEXT	当次 Merkle Root	快照值，供后续比对使用
created_at	TIMESTAMP	操作时间	审计时间线依据

表关系与隐私设计原则

四张表之间通过外键关联，整体以订单号为核心索引构建数据流。`users` 与 `orders` 通过 `user_id` 关联，`orders` 与 `messages` 通过 `order_id` 关联，`audit_logs` 通过 `order_id` 与订单和消息建立审计关系。

在隐私保护方面,数据库设计遵循以下原则:其一,消息明文不落库,`messages.content` 字段存储 SM4-CBC 密文,明文只在服务端内存中短暂存在;其二,`users.pid_r` (随机数 r) 与 `users.pid` 均仅服务端维护,前端不可见,骑手端不可见;其三,`orders.note` 备注字段在 API 响应中对骑手端和管理员端屏蔽,仅在用户本人查询订单时返回;其四,`messages.sender_pid` 字段中存储的是 PID 而非用户名,管理员默认视图也不直接暴露 PID 对应的真实用户名。

3.7 用户注册与防机器注册机制

注册流程概述

FoodShield 的用户注册流程在普通用户名注册基础上增加了口令认证和数学验证码两道机制，以降低机器批量注册和匿名身份滥用风险。完整注册流程如下：

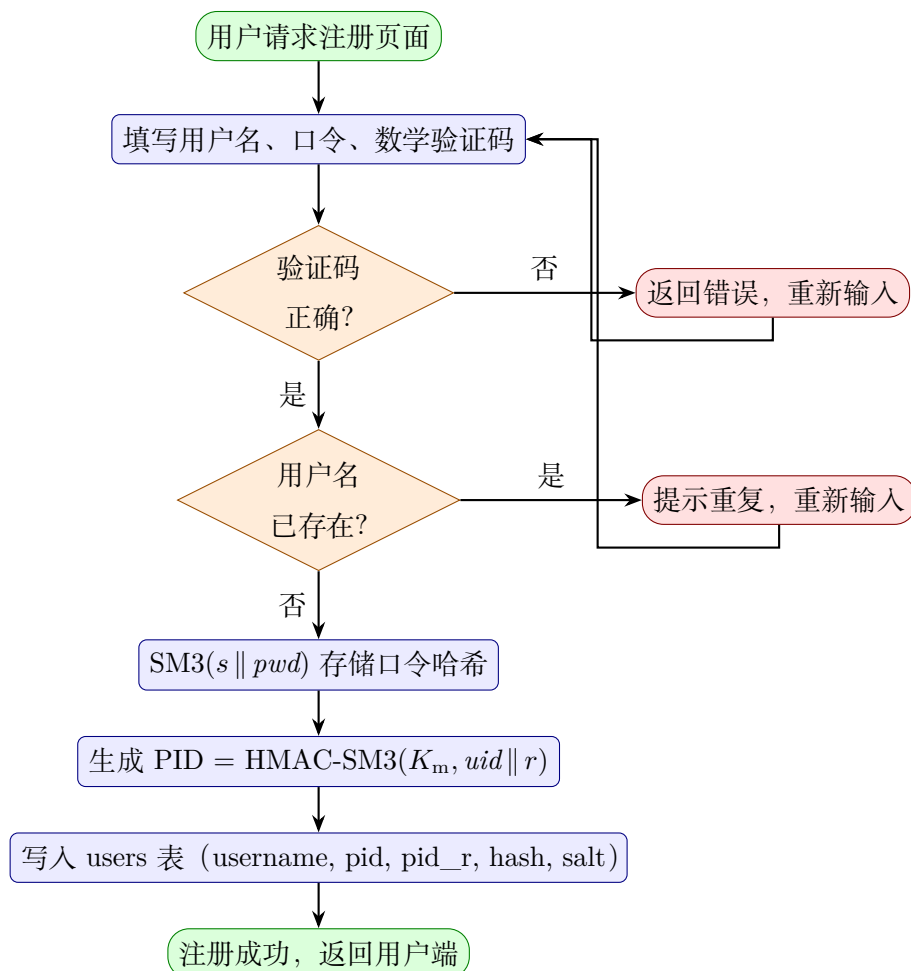


图 7: 用户注册流程图

1. 用户访问注册页面, 前端向服务器请求验证码题目 (GET /captcha);
2. 服务器随机生成一道整数四则运算题, 将答案存入服务端 session, 向前端返回题目字符串;
3. 用户填写用户名、口令(两次确认)和验证码答案, 提交注册请求 (POST /register);
4. 服务器依次执行: 验证码比对、用户名唯一性校验、口令长度校验、口令一致性校验;

5. 校验通过后, 生成随机盐值 s , 计算口令存储哈希:

$$h_{\text{pwd}} = \text{SM3}(s\|\text{password})$$

将 $\langle \text{username}, h_{\text{pwd}}, s \rangle$ 写入 `users` 表;

6. 服务器以数据库内部 `user_id` 为输入, 调用 PID 生成模块, 生成用户匿名身份 PID, 写入 `users.pid` 和 `users.pid_r`;
7. 注册成功后自动完成登录, 服务端 `session` 记录 `user_id` 和 `username`, 前端跳转至用户主页。

口令存储机制

为保护用户口令在数据库泄露场景下的安全性, 系统采用加盐哈希存储方案, 而非存储明文口令。具体地, 每位用户注册时, 服务器使用 `secrets.token_hex(16)` 生成一个 128 位随机盐值 s , 对拼接后的字符串执行 SM3 哈希:

$$h_{\text{pwd}} = \text{SM3}(s\|\text{password})$$

数据库中仅保存 $\langle s, h_{\text{pwd}} \rangle$, 原始口令在计算完成后即丢弃。登录时, 服务器从数据库读取 s , 对用户提交的口令重新计算哈希, 并使用恒定时间比较函数(`hmac.compare_digest`)与 h_{pwd} 对比, 避免时序侧信道攻击。

数学验证码机制

FoodShield 采用服务端 `session` 管控的数学验证码机制抵御机器批量注册攻击:

1. 每次获取验证码时, 服务器从 $[1, 20]$ 范围内随机抽取两个整数, 随机选择加法或减法, 生成题目字符串 (如 `"13 + 7 = ?"`);
2. 正确答案存入服务端 `session` (`session["captcha_answer"]`), 不在前端任何位置泄露;
3. 注册提交时, 服务器从 `session` 读取答案并与用户提交值比较; 比对后无论成功与否, 立即从 `session` 中删除该答案 (一次性使用), 防止枚举重试;
4. 若 `session` 中不存在答案 (如已过期或被提前消耗), 注册请求直接拒绝。

该机制能够有效阻止无交互式脚本批量注册，因为攻击者需要每次实时解析题目才能通过验证，而服务端 session 的一次性特性也排除了重放答案的可能。

注册完成后的 PID 初始化

用户注册成功后，服务器以新分配的 `user_id` 为基础输入，调用 PID 生成函数，将生成的 PID 及随机数 r 分别更新至 `users.pid` 和 `users.pid_r`。从此，用户在系统中的通信身份以 PID 作为唯一标识，`username` 仅用于登录认证，不参与订单通信流程。PID 生成的详细设计见 3.8 节。

3.8 PID 匿名身份生成机制

机制概述

PID (Pseudo-Identity, 伪身份标识) 是 FoodShield 系统中用户在通信和日志中的唯一匿名代号。PID 不等同于用户名，也不等同于数据库内部 `user_id`，而是通过带密钥的哈希函数对用户标识和随机数进行混淆后得到的不可逆摘要。系统在用户注册完成后自动生成 PID，用户在通信过程中以 PID 作为发送方标识，骑手端和管理员端默认不直接展示 PID 对应的真实身份。

生成公式

PID 的生成公式为：

$$PID = \text{HMAC-SM3}(K_{\text{master}}, \text{userID} \| r)$$

其中：

- K_{master} 为系统主密钥，由服务端统一管理，不对外暴露；
- userID 为该用户在数据库中的内部整数 id（注册时自增分配）；
- r 为 128 位随机数（`secrets.token_hex(16)` 生成），每位用户独立随机，与 PID 一同保存于 `users.pid_r` 字段；
- $\|$ 表示字符串拼接；
- HMAC-SM3 为以 SM3 为底层哈希函数的消息认证码，输出 256 位（64 位十六进制字符串）。

生成时机与存储

PID 在用户首次完成注册时由服务端自动生成，写入 `users` 表。由于 PID 依赖 `user_id`，而 `user_id` 在 `INSERT` 操作完成后才能确定，因此注册流程采用两步写入策略：先插入临时占位 PID，获取自增 `user_id` 后再调用 PID 生成函数，将最终 PID 和随机数 r 更新至数据库。

可见性策略

PID 的对外可见性遵循“最小暴露”原则：

- **用户端**：用户仅在登录响应中短暂接收 PID（用于后续订单认证），不在任何普通业务页面长期展示。
- **骑手端**：骑手端接口响应中不包含 PID 字段，骑手无法通过正常页面获知与其通信的用户 PID。
- **管理员端**：管理员默认视图仅展示消息哈希和订单摘要，不展示 `sender_pid` 的明文值；PID 仅在条件溯源授权流程中被关联至真实用户名。
- **数据库内部**：`users.pid_r`（随机数 r ）和 `users.pid` 均保存于服务端数据库，仅服务器进程可访问，不通过 API 直接对外暴露。

跨订单不可链接性

由于每位用户的 PID 由随机数 r 参与生成，不同用户之间的 PID 不存在可预测的关联关系。骑手在多次接单过程中，即使多次与同一用户通信，在缺少 K_{master} 和 r 的情况下，也无法通过 PID 判断是否为同一用户。HMAC-SM3 的伪随机性确保：在 K_{master} 保密的前提下，已知 PID 无法还原 `userID`，也无法枚举其他用户的 PID，从而实现跨订单不可链接性。

3.9 订单 Token 认证机制

机制概述

订单 Token 是用户进入订单通信通道前必须提交的认证凭证。Token 由服务器在订单创建时生成，并与订单绑定保存。用户发起 WebSocket 入房请求时，服务器对 Token 的合法性、归属关系和时效性进行三重验证，缺一不可。

该机制的核心设计思路是：Token 不是一个简单的随机字符串，而是将订单号、用户 PID、时间戳和随机数绑定在一起的 HMAC-SM3 认证码。攻击者在不知道订单认证密钥 K_{order} 的情况下，无法伪造任何合法 Token，也无法从一个合法 Token 推导出其他订单的凭证。

Token 生成公式

Token 的理想生成公式为：

$$\text{Token} = \text{HMAC-SM3}(K_{\text{order}}, \text{orderID} \parallel \text{PID} \parallel \text{timestamp} \parallel \text{nonce})$$

其中：

- K_{order} 为系统订单认证密钥，由服务端统一管理；
- orderID 为随机 UUID 订单号，防止顺序枚举；
- PID 为发起订单的用户匿名身份标识；
- timestamp 为 Token 生成时的 Unix 时间戳（秒级），用于有效期校验；
- nonce 为随机数，进一步降低重放攻击风险；
- Token 生成后， $\langle \text{token}, \text{timestamp} \rangle$ 一并写入 `orders` 表供后续验证使用。

引入 nonce 的目的在于：即使攻击者能够在 Token 有效期内截获同一组 $(\text{orderID}, \text{PID}, \text{timestamp})$ 的请求，相同的时间戳配合不同的 nonce 仍会产生不同的 Token 值，从而进一步降低重放攻击成功率。

Token 验证流程

用户提交 `join_order` 请求时，服务器执行以下验证步骤：

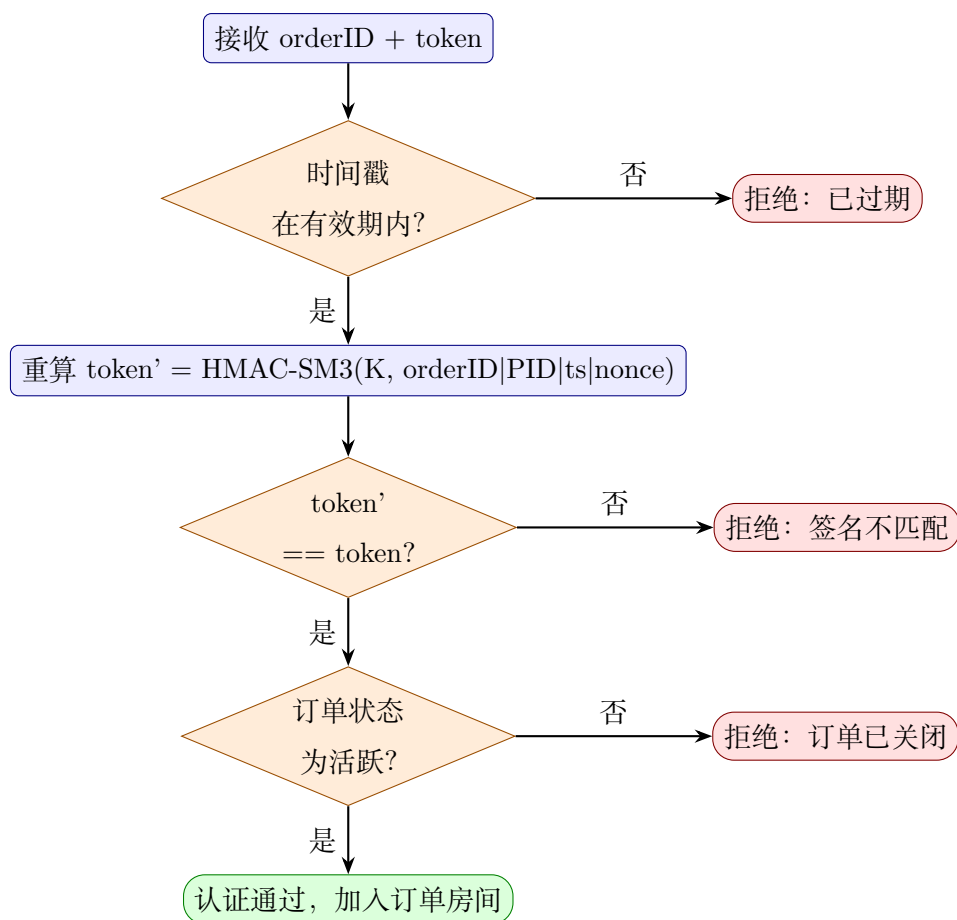


图 8: 订单 Token 三重验证流程图

1. **有效期校验**: 读取请求中的 *timestamp*, 与当前服务器时间比较, 若超出有效窗口 (默认 3600 秒), 拒绝本次请求;
2. **重新计算 Token**: 以数据库中保存的 K_{order} 、*orderID*、PID、*timestamp* (及 *nonce*) 为输入, 重新调用 HMAC-SM3 计算期望 Token;
3. **比对验证**: 将重新计算得到的期望 Token 与请求中提交的 Token 进行恒定时间比较, 一致则通过, 否则拒绝;
4. **订单状态检查**: 验证通过后进一步检查订单状态, 确保订单处于合法状态 (如未被取消), 方可允许用户加入通信房间。

安全性分析

Token 机制提供了以下安全保障:

- **抗伪造性**: Token 由 HMAC-SM3 生成, 在 K_{order} 保密的前提下, 攻击者无法在不知道密钥的情况下构造合法 Token;

- **绑定性**: Token 将 *orderId*、PID、*timestamp*、*nonce* 绑定为一个整体, 任意字段被篡改均会导致验证失败;
- **时效性**: 时间戳有效期机制限制 Token 的可用窗口, 降低截获后长期利用的风险;
- **抗重放性**: *nonce* 的引入保证即使相同的订单号和时间戳也会产生不同的 Token, 进一步降低重放成功概率。

3.10 用户端与骑手端匿名通信机制

通信通道设计

FoodShield 采用基于 Flask-SocketIO 的 WebSocket 通道实现用户端与骑手端之间的实时消息通信。系统以订单号 (*order_id*) 作为通信房间的唯一标识, 每个订单对应一个独立的 WebSocket Room, 不同订单的通信消息在房间层面实现隔离, 互不干扰。

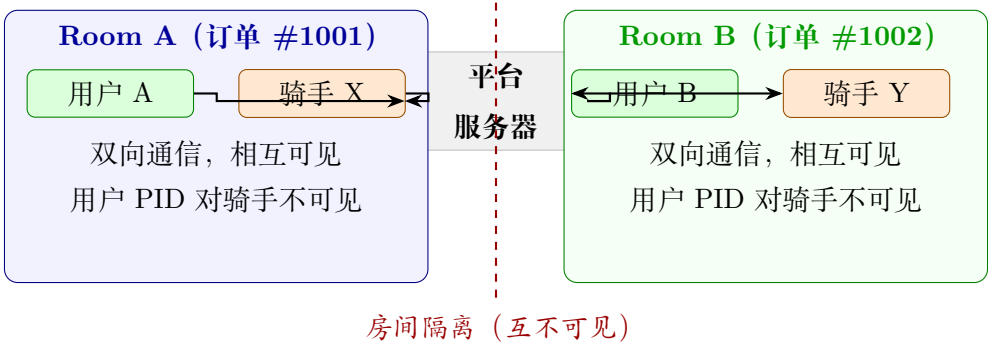


图 9: 订单房间隔离示意图 (不同订单房间成员相互不可见)

入房认证流程

用户端入房 (*join_order* 事件) 需提交以下字段:

$\{ order_id, PID, timestamp, token, role \}$

服务器按 3.9 节描述的 Token 验证流程完成三重校验 (有效期、Token 合法性、订单存在性), 验证通过后执行 *join_room(order_id)*, 将该 WebSocket 连接加入对应房间, 同时广播系统消息通知房间内成员。

骑手端入房 (join_order_as_rider 事件) 需提交:

$$\{ order_id, role \}$$

骑手端不需要提交 Token, 但服务器会检查订单状态, 仅当订单处于 taken、delivering 或 completed 状态时, 才允许骑手加入对应房间。这一状态约束保证只有已接单的骑手才能进入订单通信通道, 避免任意骑手随意侦听订单房间。

消息转发与字段最小化

用户端或骑手端通过 send_message 事件发送消息时, 消息负载包含:

$$\{ order_id, sender_pid, role, content \}$$

服务器在内存中完成以下操作后, 再将消息广播至房间:

1. 生成全局唯一 msg_id (UUID) 和 ISO 8601 格式时间戳;
2. 调用消息哈希函数计算 message_hash (详见 3.11 节);
3. 调用 SM4-CBC 对明文 content 加密, 将密文写入 messages 表 (详见 3.11 节);
4. 触发 Merkle 快照更新, 将新的 merkle_root 附加到广播消息中;
5. 通过 emit("receive_message", msg, room=order_id) 将消息广播至订单房间内所有成员。

广播给骑手端的消息中包含 sender_pid 字段, 但骑手端前端界面不展示该字段, 骑手仅能看到消息内容和发送方角色 (user 或 rider), 而无法直接接触 PID 原始值, 从而保障用户匿名性。

房间隔离与越权防护

每个订单对应一个独立房间, 服务器在处理 send_message 事件时, 还会验证订单号对应的订单是否存在。通信消息只在同一 order_id 的房间内广播, 无法跨订单传播。骑手端和用户端只能通过正常的入房鉴权流程进入自己有资格参与的订单通信房间, 无法旁听其他订单的通信内容。

3.11 消息加密存储与哈希摘要机制

消息加密存储

通信消息在写入数据库之前，经过 SM4-CBC 加密处理，数据库中不存储任何明文内容。消息处理的完整流水线如图 10 所示，加密与哈希计算并行进行，随后一并写入数据库。

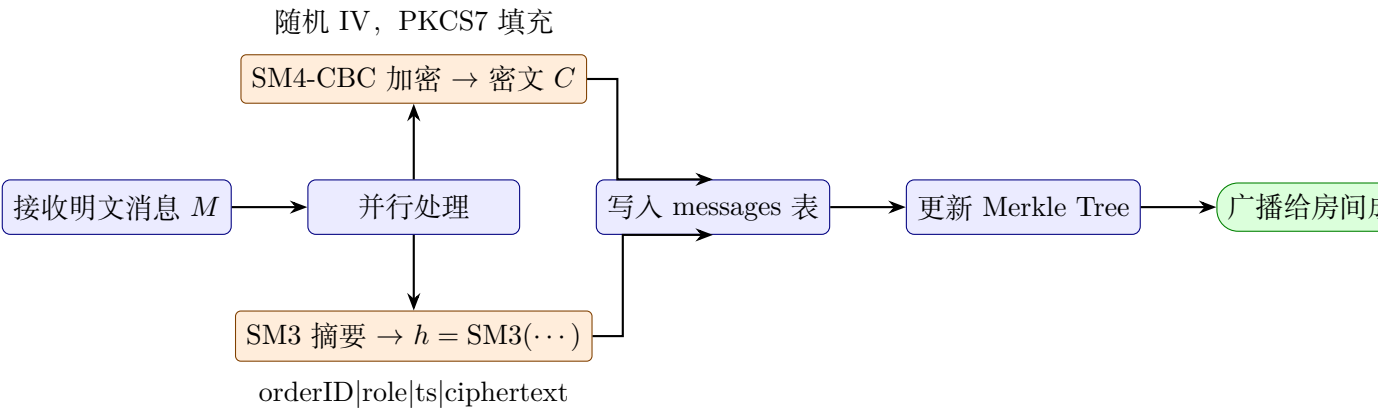


图 10: 消息处理流水线（加密存储与哈希计算并行）

加密流程如下：

- 1. 系统从环境变量 FOODSHIELD_SM4_KEY 读取 SM4 密钥（128 位），若未配置则使用系统内置默认密钥；
- 2. 使用 secrets.token_bytes(16) 生成随机 IV（初始向量），每条消息使用独立 IV；
- 3. 对明文字节串执行 PKCS#7 填充，使数据长度对齐至 16 字节块边界；
- 4. 执行 SM4-CBC 加密，得到密文 C；
- 5. 将 IV||C 拼接后以十六进制字符串形式存入 messages.content 字段。

存储格式可表示为：

$$\text{content} = \text{hex}(IV \parallel \text{SM4-CBC}_K(IV, M))$$

其中 IV 占前 16 字节（32 位十六进制字符），后续为密文。解密时，系统从 content 字段读取十六进制字符串，提取前 16 字节作为 IV，其余部分作为密文执行 SM4-CBC 解密，并去除 PKCS#7 填充后还原明文。

每条消息使用独立随机 IV 的设计保证了相同明文在不同时间加密后产生不同密文，避免攻击者通过密文相等推断消息内容是否相同。

消息哈希摘要计算

每条消息在写入数据库前，服务端在内存中对消息的明文字段进行联合哈希计算，生成 `message_hash`，该哈希值作为 Merkle Tree 的叶子节点参与完整性验证。

消息哈希公式为：

$$h_i = \text{SM3}(\text{orderID} \parallel \text{senderPID} \parallel \text{role} \parallel \text{content}_{\text{plain}} \parallel \text{timestamp})$$

其中各字段之间使用分隔符 `|` 拼接，防止字段边界歧义。`contentplain` 为消息明文，哈希计算在服务端内存中完成，计算完成后明文即被 SM4 加密替换，数据库中不保存明文摘要。

上述设计满足以下安全目标：

- **内容绑定**：哈希值绑定了订单号、发送方身份、角色、明文内容和时间戳，任意字段被篡改都会导致重新计算的哈希与存储值不一致；
- **明文隔离**：哈希基于明文计算，但数据库中仅存储密文，攻击者即使获取数据库内容，也无法从 `content` 字段直接还原哈希输入；
- **完整性可验证**：后续验证时，服务端先对 `content` 字段执行 SM4 解密得到明文，再按相同公式重算哈希，与存储的 `message_hash` 对比，实现单条消息层面的完整性验证。

管理员访问控制

管理员查询消息记录时，`/admin/messages/{order_id}` 接口仅返回 `msg_id`、`order_id`、`sender_pid`、`role`、`message_hash` 和 `timestamp` 字段，不返回 `content` 密文字段。Merkle 完整性验证只需 `message_hash` 列表，管理员无需接触消息密文即可完成日志验证，实现审计与明文访问的权限隔离。

3.12 Merkle 日志完整性验证机制

叶子节点构造

Merkle Tree 以订单内全部消息的哈希值列表作为叶子节点，叶子节点 L_i 即为第 i 条消息的 `message_hash`：

$$L_i = h_i = \text{SM3}(\text{orderId} \parallel \text{senderPID}_i \parallel \text{role}_i \parallel \text{content}_{i,\text{plain}} \parallel \text{timestamp}_i)$$

叶子节点按消息写入顺序排列（`timestamp ASC`，`id ASC`），顺序的固定性保证任意消息重排均会导致 Merkle Root 改变。

树的构建规则

Merkle Tree 采用迭代方式自底向上构建：

1. 以所有叶子节点哈希值的小写十六进制表示作为第 0 层；
2. 每层相邻两个节点两两拼接后计算 SM3 哈希，得到父节点：

$$\text{parent}(i) = \text{SM3}(L_{2i} \parallel L_{2i+1})$$

3. 若当前层节点数为奇数，最后一个节点与自身拼接（复制）后参与父节点计算；
4. 重复上述过程直至仅剩一个节点，该节点即为 Merkle Root R ；
5. 若订单内无消息，Root 取固定值 `SM3("EMPTY")`。

快照触发时机

Merkle Root 快照写入 `audit_logs` 表的触发时机包括以下几种：

- **实时快照**：每条消息发送成功并写入数据库后，服务器立即调用 `create_merkle_snapshot` 函数，以当前全部消息哈希重新计算 Root，将 `(order_id, MERKLE_ROOT_UPDATED, root, message_count)` 写入 `audit_logs`；
- **管理员手动快照**：管理员可通过 `POST /admin/snapshot/{order_id}` 接口手动触发某订单的 Merkle Root 快照；

- **历史补全快照：**管理员可通过 `POST /admin/backfill_snapshots` 接口对所有尚未生成快照的历史订单批量补全 Root 快照。

完整性验证流程

管理员执行日志完整性验证时 (`POST /admin/verify/{order_id}`)，系统按以下步骤完成验证：

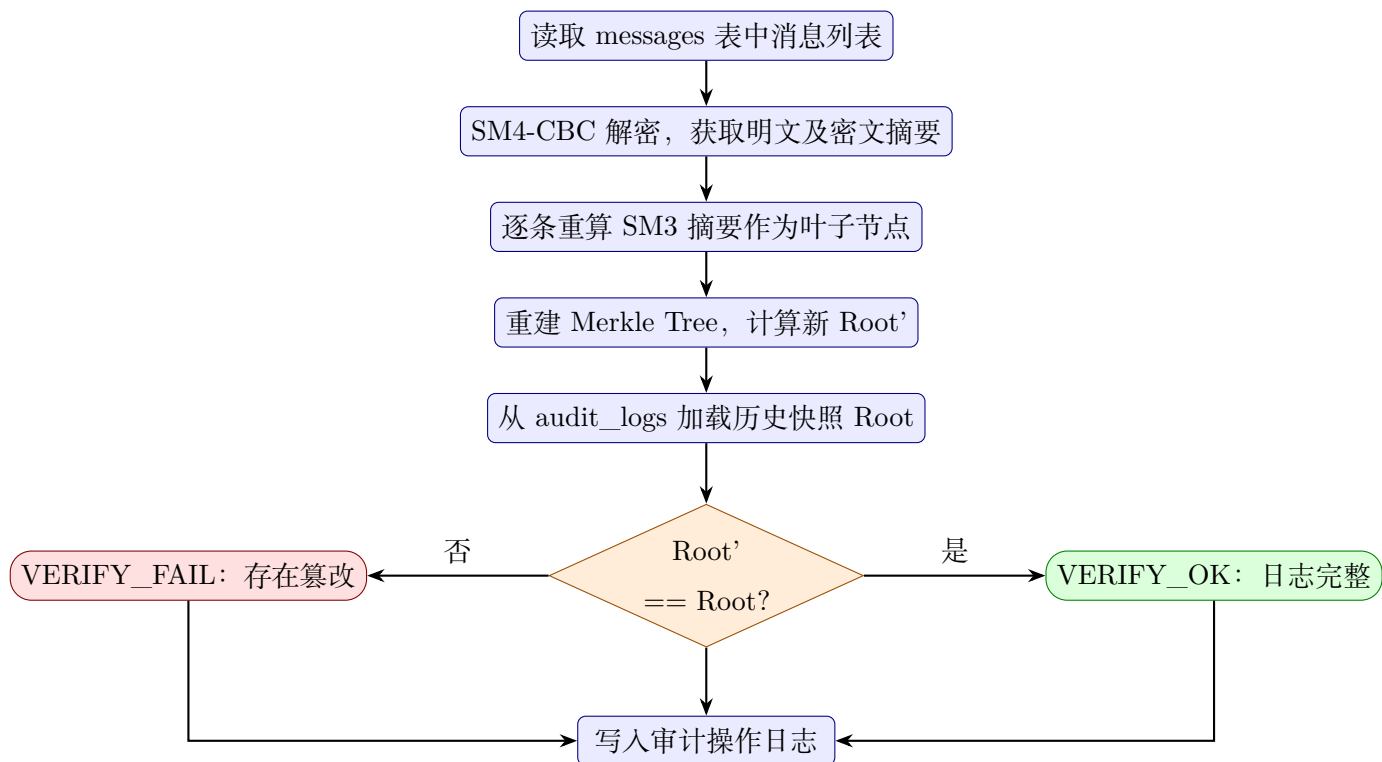


图 11: Merkle 日志完整性验证流程图

1. 从数据库按序读取订单内所有消息，对 `content` 字段执行 SM4 解密，还原明文；
2. 对每条消息按相同公式重新计算消息哈希 h'_i ，与数据库中存储的 `message_hash` 对比；若存在不匹配的条目，记录差异列表；
3. 以重新计算的哈希序列 $[h'_1, h'_2, \dots, h'_n]$ 为叶子节点重建 Merkle Tree，得到当前 Root R' ；
4. 从 `audit_logs` 读取最近一次 `MERKLE_ROOT_UPDATED` 快照，取其 `merkle_root` 字段作为历史快照值 R_{snap} ；

5. 比较 $R' \stackrel{?}{=} R_{\text{snap}}$: 若一致且无哈希不匹配条目, 则判定完整性验证通过 (VERIFY_OK); 否则判定为验证失败 (VERIFY_FAIL);
6. 将验证结果 (包括不匹配哈希列表、当前 Root、快照 Root 和消息数量) 写入 audit_logs。

该机制能够检测以下篡改行为:

- 修改某条消息的内容或时间戳: 重新计算的 h'_i 将与存储的 message_hash 不一致, 且 $R' \neq R_{\text{snap}}$;
- 删除某条消息: 叶子节点数量减少, 树结构改变, $R' \neq R_{\text{snap}}$;
- 插入伪造消息: 新增叶子节点, $R' \neq R_{\text{snap}}$;
- 重排消息顺序: 叶子节点顺序改变, $R' \neq R_{\text{snap}}$ 。

3.13 条件溯源与管理员审计机制

设计原则

FoodShield 的条件溯源机制以”投诉驱动、完整性前置、关键词双重门槛”为核心设计原则。管理员不能随意对任意 PID 发起溯源, 而必须在满足以下三个条件后才能完成真实身份解析: (1) 提供有效订单号; (2) 底层日志完整性验证通过; (3) 消息内容命中指定违规关键词。

溯源申请流程

条件溯源的完整流程如图 12 所示, 包含”完整性前置”与”关键词命中”两道不可绕过的门槛:

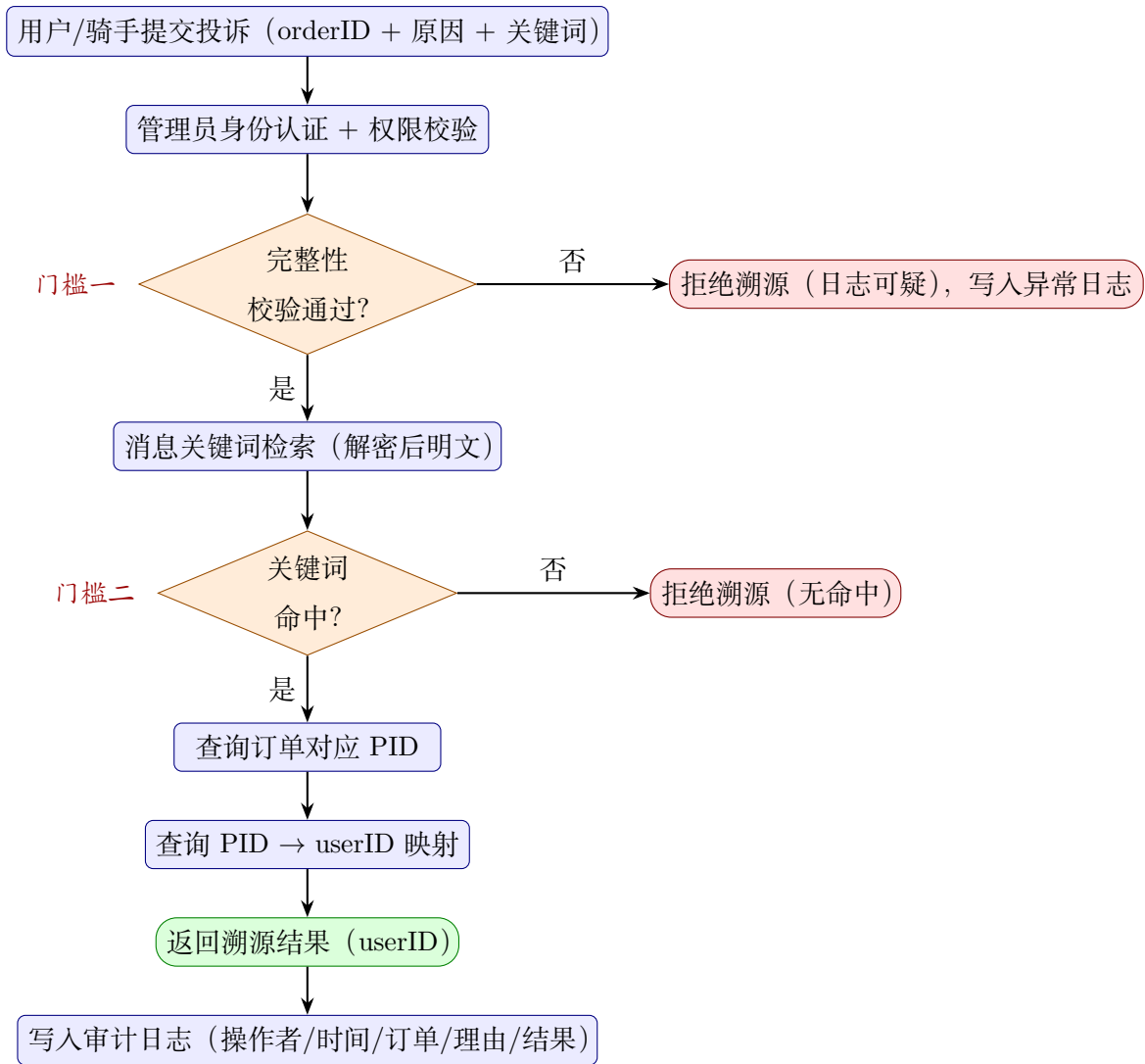


图 12: 条件溯源详细流程图 (含完整性前置校验与关键词双重门槛)

1. **申请提交**: 用户端或骑手端可在订单出现异常 (骚扰、违规发言、恶意投诉等) 情况下, 提交 $\langle order_id, keyword, reason \rangle$ 申请溯源;
2. **完整性前置校验**: 管理员端收到申请后, 服务器首先调用 `verify_order_integrity` 对目标订单执行 Merkle 完整性验证 (3.12 节)。若验证失败, 系统判定证据链已被污染, 阻断后续溯源操作并返回告警;
3. **关键词命中检测**: 完整性校验通过后, 服务器对该订单内所有消息的明文 `content` 进行关键词匹配, 收集包含指定关键词的消息发送方 PID 集合 $\mathcal{P}_{hit}$;
4. **PID 解析**: 若 $\mathcal{P}_{hit} \neq \emptyset$, 服务器在 `users` 表中查询各 PID 对应的 `username`, 得到真实用户身份列表;
5. **审计日志记录**: 无论溯源成功与否, 操作结果 (操作者、目标订单、PID、关键词、

溯源状态)均写入 `audit_logs`, 动作类型分别为 `TRACE_SUCCESS` 或 `TRACE_FAIL`;

6. **结果返回**: 管理员端展示涉嫌违规用户的 PID 和用户名, 并提示下一步处理建议。

管理员权限边界

管理员端的权限访问受以下机制约束:

- **登录认证**: 管理员需通过 `POST /admin/login` 接口完成身份认证, 验证用户名和口令后才能访问 `/admin/*` 系列接口;
- **装饰器鉴权**: 所有管理员接口通过 `@admin_required` 装饰器拦截, 未经认证的请求将被拒绝并记录 `TRACE_DENIED` 审计日志;
- **默认隐藏明文**: `/admin/messages/{order_id}` 接口只返回消息哈希和元数据, 不返回消息密文, 管理员无法通过常规查询接口读取通信明文;
- **操作全程记录**: 管理员登录、登出、查询、验证、溯源成功和溯源失败等操作均写入 `audit_logs`, 使管理员行为本身也处于可追踪的审计视野中。

双重门槛的安全意义

条件溯源采用”完整性前置 + 关键词命中”双重门槛, 而不是允许管理员直接按 PID 查询真实身份, 其安全意义在于:

- 若仅依靠管理员主观判断, 溯源接口可能被滥用为隐私查询工具, 导致用户即使没有违规也可能被追踪;
- 完整性前置校验保证在证据链被污染的情况下不会基于伪造日志执行溯源, 保护被追责方的合法权益;
- 关键词命中门槛要求违规行为在消息内容中留有可验证痕迹, 避免基于推测或主观意见发起溯源。

3.14 三端摘要一致性增强机制

设计动机

在标准的 Merkle Tree 完整性验证方案中, Merkle Root 快照保存在服务端数据库 (`audit_logs` 表) 中。若攻击者同时获得数据库写权限, 理论上可以在篡改消息

内容后同步伪造 `audit_logs` 中的快照 Root，使得完整性验证仍然通过。

为提高攻击者同时伪造日志和快照的难度，FoodShield 引入三端摘要一致性增强机制：服务端在每次 Merkle Root 更新后，通过 WebSocket 消息将最新 `merkle_root` 推送给订单房间内的用户端和骑手端，前端将其存储于本地（`localStorage`）；审计时，管理员将三方 Root（服务端快照、用户端上报、骑手端上报）进行三角比对，任一方不一致则触发告警。

工作流程

1. **Root 随消息广播**：每条消息成功入库后，服务器调用 `create_merkle_snapshot` 生成最新 Root，并将其附加在 `receive_message` 事件的响应中推送至房间：

$$\text{msg.merkle_root} \leftarrow \text{MerkleRoot}([h_1, h_2, \dots, h_n])$$

2. **客户端本地留存**：用户端和骑手端前端在收到每条消息时，将 `merkle_root` 字段保存至 `localStorage`（以 `order_id` 为键），本地仅保存最新值；
3. **主动上报**：通信结束或管理员发起审计前，用户端和骑手端可向 `POST /report_merkle_root` 接口上报本地保存的 Root：

$$\{ \text{order_id}, \text{merkle_root}, \text{role} \} \rightarrow \text{audit_logs.action} = \text{CLIENT_ROOT_REPORTED}$$

4. **三方比对**：管理员执行 `POST /admin/verify/{order_id}` 时，服务器在完成本地 Merkle 验证后，额外从 `audit_logs` 中读取用户端和骑手端最近一次上报的 Root，进行三角比对：

$$R_{\text{server}} \stackrel{?}{=} R_{\text{user}} \stackrel{?}{=} R_{\text{rider}}$$

若三者全部一致，`all_match = true`；否则返回 `all_match = false` 并告警。

安全性提升

三端一致性机制将完整性验证的信任锚扩展至通信双方的本地留存，使攻击者需要同时满足以下条件才能伪造一致结果：

- 修改服务端 `messages` 表中的消息内容；
- 同步伪造 `audit_logs` 中的 Merkle Root 快照；

- 同时控制用户端和骑手端本地存储，或阻止其上报真实 Root。

三个条件需同时满足，实际攻击难度大幅提升。需要说明的是，该机制以“可选增强”而非强制前置条件的方式实现：若客户端未上报 Root（如通信异常中断），服务端仍可基于本地快照独立完成完整性验证；三方比对仅在客户端 Root 存在时才执行额外比对步骤。

3.15 方案安全性分析

本节对 FoodShield 的安全设计进行半形式化分析，依次针对 3.4 节所列的八项安全目标，说明系统采用的对应机制如何在威胁模型假设下提供安全保障。

G1：匿名性

目标：骑手端和外部攻击者在日常通信中无法从系统返回的数据中确定用户真实身份或将多次通信关联至同一用户。

分析：系统为每位用户生成 $PID = \text{HMAC-SM3}(K_{\text{master}}, userID \| r)$ 。在 K_{master} 保密的前提下，HMAC-SM3 具有伪随机性，使得 PID 在计算上不可区分于随机字符串，攻击者无法从 PID 还原 $userID$ 。骑手端接口响应不暴露 PID 字段，管理员默认视图不展示 PID 与用户名的映射，普通业务流程中没有任何接口将 $(PID, username)$ 同时返回给骑手或外部调用方。

复杂度估计：在不知道 K_{master} 的情况下，穷举攻击 HMAC-SM3 需要 2^{256} 次查询，超出实际计算能力。

G2：认证性

目标：只有持有合法 Token 的订单参与方才能进入对应订单通信通道，攻击者无法伪造或复用 Token 冒充合法用户。

分析：Token 公式为 $\text{HMAC-SM3}(K_{\text{order}}, orderID \| PID \| timestamp \| nonce)$ 。在 K_{order} 保密的前提下，HMAC 的不可伪造性保证攻击者无法在不知道密钥的情况下构造任何有效 Token。时间戳有效期（默认 3600 秒）限制了截获 Token 后的可利用时间窗口；nonce 的引入确保即使时间戳相同，重放攻击也无法复现合法 Token。

复杂度估计：在随机预言模型下，HMAC-SM3 满足 EUF-CMA（存在不可伪造性），伪造成功概率不超过 $q/2^{256}$ ，其中 q 为查询次数。

G3: 机密性

目标：消息内容在数据库泄露场景下不被直接读取；管理员无需接触明文即可完成审计操作。

分析：消息明文经 SM4-CBC 加密后以密文形式存储，每条消息使用独立随机 IV，相同明文在不同时间产生不同密文，防止基于密文相等进行的内容推断。管理员消息查询接口（/admin/messages）只返回 message_hash 和元数据字段，不返回 content 字段，在接口层面实现了审计与明文访问的权限分离。

SM4-CBC 安全性：SM4 是国家密码局发布的分组密码标准，密钥长度 128 位，CBC 模式在 IV 随机且保密的条件下满足 IND-CPA 安全性，穷举密钥需要 2^{128} 次操作。

G4: 完整性

目标：任何对历史通信记录（消息内容、顺序、数量）的修改均可被检测。

分析：每条消息的 message_hash 绑定了订单号、PID、角色、明文内容和时间戳五个字段，SM3 的抗碰撞性保证修改任意字段后哈希值以压倒性概率改变（碰撞概率不超过 2^{-128} ）。Merkle Tree 将所有消息哈希组织为树形结构，任意叶子节点变化均会级联改变 Root 值。三端摘要一致性机制进一步将 Root 快照分散至用户端、骑手端和服务端三方留存，攻击者需同时篡改三方数据才能伪造一致结果。

G5: 可追责性与可审计性

目标：发生纠纷时能够通过合法流程追溯违规行为；管理员操作本身也处于可追踪的审计视野中。

分析：条件溯源的”完整性前置 + 关键词双重门槛”设计使溯源操作与违规证据直接绑定，防止无故溯源；所有管理员操作（包括溯源成功、溯源失败、完整性验证结果）均写入 audit_logs，形成不可篡改的操作时间线（在 Merkle 保护范围内）。

G6: 抗滥用能力

目标：防止机器批量注册生成大量匿名身份，以及利用匿名性发起垃圾消息或骚扰。

分析：注册阶段的数学验证码（服务端 session 一次性）要求攻击者每次注册都实时解析新题目，不能通过重放答案完成批量注册；口令长度下限和用户名唯一性

约束进一步增加了批量注册的操作成本；订单号与 PID 的绑定机制使每次通信都要经过 Token 认证，无状态连接无法进入通信通道。

G7：隐私最小化

目标：系统各端只获取完成自身功能所必需的最小信息集合。

分析：骑手端接口不返回用户 PID 和备注字段；管理员默认接口不返回消息密文和用户真实身份；`orders.note` 备注字段在骑手端和管理员端的 API 响应中被屏蔽；`users.pid_r`（随机数）不通过任何前端接口暴露。字段最小化从数据结构和接口设计两个层面共同实现隐私最小化原则。

综合评估

综合来看，FoodShield 通过 HMAC-SM3 订单认证、SM4-CBC 加密存储、SM3 消息摘要、Merkle Tree 完整性验证、条件溯源约束和三端摘要一致性增强等机制的组合，在外卖订单通信场景中实现了匿名性、认证性、机密性、完整性、可追责性、可审计性和抗滥用能力的多目标安全保障。系统的安全设计以订单为核心索引，将业务流程与密码学机制紧密耦合，避免了安全机制游离于业务逻辑之外导致的防护盲区。

作品实现

- 4.1 系统开发环境
- 4.2 后端服务实现
- 4.3 用户端功能实现
- 4.4 骑手端功能实现
- 4.5 管理员端功能实现
- 4.6 注册、下单与订单认证流程实现
- 4.7 WebSocket 通信流程实现
- 4.8 Merkle 快照与完整性验证实实现
- 4.9 条件溯源流程实现
- 4.10 系统运行界面

作品测试与分析

(建议包括测试方案、测试环境搭建、测试设备、测试数据、结果分析等)

5.1 测试环境

5.2 功能测试

5.3 安全性测试

5.4 日志篡改检测测试

5.5 越权访问测试

5.6 性能测试

5.7 对比分析

功能展示与创新性说明

(本部分内容主要说明作品的创新性)

6.1 场景创新

6.2 机制创新

6.3 安全模型创新

6.4 系统闭环创新

6.5 应用价值

总结

7.1 作品总结

7.2 未来展望

参考文献

1. 全国人民代表大会常务委员会. 中华人民共和国密码法 [Z]. 主席令第三十五号, 2019-10-26.
2. 全国人民代表大会常务委员会. 中华人民共和国个人信息保护法 [Z]. 2021-08-20.
3. 全国人民代表大会常务委员会. 中华人民共和国数据安全法 [Z]. 2021-06-10.
4. 国务院. “十四五”数字经济发展规划 [Z]. 国发〔2021〕29号, 2021-12.
5. GB/T 32905-2016. 信息安全技术 SM3 密码杂凑算法 [S]. 北京: 中国标准出版社, 2016.
6. GB/T 32907-2016. 信息安全技术 SM4 分组密码算法 [S]. 北京: 中国标准出版社, 2016.
7. GB/T 32918-2016. 信息安全技术 SM2 椭圆曲线公钥密码算法 [S]. 北京: 中国标准出版社, 2016.
8. Bellare M, Canetti R, Krawczyk H. Keyed-Hashing for Message Authentication[S]. RFC 2104, IETF, 1997.
9. Fette I, Melnikov A. The WebSocket Protocol[S]. RFC 6455, IETF, 2011.
10. Merkle R C. A Certified Digital Signature[C]//Advances in Cryptology – CRYPTO ’89 Proceedings, LNCS vol. 435. Springer, 1989: 218–238.
11. 中国互联网络信息中心. 第 55 次中国互联网络发展状况统计报告 [R]. 2025.
12. 中国饭店协会. 2024 年中国餐饮业年度报告 [R]. 2024.
13. 韩丹东. 商品明细是隐私, 外卖员不应知晓 [N]. 法治日报, 2025-05-08(04).
14. 美团规则中心. 消费者权益保护 [EB/OL]. <https://rules-center.meituan.com/customer-rights/1>.
15. Lin X, Sun X, Ho P H, et al. GSIS: A Secure and Privacy-Preserving Protocol for Vehicular Communications[J]. IEEE Transactions on Vehicular Technology, 2007, 56(6): 3442–3456.
16. Sun Y, Zhang B, Zhao B, et al. Mix-zones: For More Private and Safer Location-Based Services[J]. IEEE Transactions on Dependable and Secure Computing, 2020.

17. Calik M, Bayrak A E, Cakir O. A Privacy-Preserving Authentication Scheme for Connected Vehicles[J]. IEEE Internet of Things Journal, 2021, 8(15): 12211–12222.
18. 郭宝安, 戴一奇. 密码学原理与实践 [M]. 北京: 清华大学出版社, 2019.
19. Stallings W. Cryptography and Network Security: Principles and Practice[M]. 8th ed. Pearson, 2020.
20. 国家密码管理局. 商用密码管理条例 [Z]. 2023-04-27.